

Audit de sécurité de l'infrastructure du
système d'information

ProSecureX

Ducousset Florian

43 rue Sadi CARNOT 17500 Jonzac

Table des matières

1) Introduction

- 1.1) Avant-propos.....4
- 1.2) Contexte général.....4
- 1.3) Cadre de la mission.....5
- 1.4) Objectif de l'audit.....5
- 1.5) Liste des compétences mises en œuvre dans le cadre du projet.....6

2) Présentation de l'entité auditée

- 2.1) Description de l'organisation.....6
- 2.2) Effectifs et organisation.....7
- 2.3) Activité principale.....8
- 2.4) Enjeux métiers liés à l'informatique.....9
- 2.5) Environnement technique général.....10

3) Cahier des charges de l'audit

- 3.1) Expression du besoin initial.....11
- 3.2) Objectifs spécifiques.....12
- 3.3) Périmètre de l'audit.....12
- 3.4) Contraintes techniques ou organisationnelles..13
- 3.5) Livrables attendus.....14
- 3.6) Matrice de responsabilité.....15
- 3.7) Durée et calendrier de l'audit.....16

4) Méthodologie

- 4.1) Méthode de collecte des données.....16
- 4.2) Outils utilisés.....17
- 4.3) Référentiels suivis.....17
- 4.4) Politique d'échantillonnage.....18
- 4.5) Limites de l'audit.....18
- 4.6) Déroulement général de l'audit.....19

5) Audit d'infrastructure

- 5.1) Politique de sécurité existante.....20
- 5.2) Analyse de la gestion des risques.....21
- 5.3) Identification des actifs sensibles.....23
- 5.4) Menaces et vulnérabilités.....24
- 5.5) Organisation de sécurité.....38
- 5.6) Rôles et responsabilités.....39
- 5.7) Plan de continuité (PRA/PCA)40
- 5.8) Gestion des incidents.....40
- 5.9) Formation et sensibilisation.....41

6) Audit technique

- 6.1) Architecture Réseau41
- 6.2) Matrice de flux et Filtrage.....42
- 6.3) Mise en œuvre technique de l'infrastructure.....43
- 6.4) Services de Supervision et Détection.....49
- 6.5) Durcissement de l'Active Directory.....50
- 6.6) Supervision et Métrologie (Centreon - Linsup)....59
- 6.7) Sécurisation de l'Hyperviseur (Proxmox).....60
- 6.8) Sauvegardes et Stockage.....62
- 6.9) Audit de sécurité et Analyse des vulnérabilités ..64
- 6.10) Vue d'ensemble des risques résiduels.....65
- 6.11) Plan de remédiation et Recommandations.....66

7) Conclusion et remerciements.....67

1) Introduction

1.1) Avant-propos

Dans le cadre de ma préparation au sein de la **Guardia Cybersecurity School**, j'ai suivi un parcours de formation visant à acquérir les compétences inscrites dans le bloc de compétence n°3 du référentiel **RNCP37680BC03 – Titre Professionnel Administrateur d'Infrastructures Sécurisées**.

Ce dossier a pour objectif de **valoriser les travaux réalisés durant cette formation**, en mettant en évidence l'application concrète des compétences attendues.

Les **compétences mobilisées**, telles qu'elles sont définies dans le référentiel, couvrent notamment :

Participer à la mesure et à l'analyse du niveau de sécurité de l'infrastructure
Participer à l'élaboration et à la mise en œuvre de la politique de sécurité
Participer à la détection et au traitement des incidents de sécurité

1.2) Contexte général

L'infrastructure **PROSECUREX** utilisée pour ce projet est un environnement de simulation hébergé chez **OVH**. Ce dispositif est mis à disposition par **Guardia** afin de répondre aux exigences pratiques de la certification.

1.3) Cadre de la mission

L'audit sera réalisé en mode **White-Box**, s'appuyant sur une visibilité **complète des systèmes et des configurations** de PROSECUREX. En **l'absence d'un environnement de test** dédié (LAB), l'ensemble des analyses est effectué directement sur l'infrastructure de production. Afin de **garantir la continuité de service** sur l'infrastructure de production, l'audit **privilégie des analyses non-intrusives planifiés** avec le DSI, tout en prenant des **snapshots avant chaque intervention** technique pour plus de sécurité.

1.4) Objectif de l'audit

L'objectif principal de cette mission est de fournir à la direction de **PROSECUREX** une vision claire et objective de sa **posture de sécurité actuelle**. Cet audit vise à :

Identifier les vulnérabilités exploitables	Détecter les défauts de configuration (Active Directory, Firewall, Centreon) avant qu'elles ne soient exploitées par un attaquant.
Évaluer la conformité	Vérifier que l'infrastructure respecte les bonnes pratiques de sécurité de l'ANSSI et l'ISO 27001.
Réduire la surface d'attaque	Proposer des mesures de remédiation pour limiter la surface d'attaque sur l'ensemble de l'infrastructure.

Garantir la continuité de service	S'assurer que les mécanismes de détection (Centreon) et de protection (OPNsense) sont opérationnels pour réagir en cas d'incident.
-----------------------------------	--

1.5) Liste des compétences mises en œuvre

Participer à la mesure et à l'analyse du niveau de sécurité de l'infrastructure	Mesure et analyse du niveau de sécurité
Participer à l'élaboration et à la mise en œuvre de la politique de sécurité	Élaboration de la PSSI
Participer à la détection et au traitement des incidents de sécurité	Détection et traitement (Mise en place de la surveillance des logs via WAZUH)

2) Présentation de l'entité auditée

2.1) Description de l'organisation

PROSECUREX est une ESN (Entreprise de Services du Numérique) fondée en 2020 et basée à **Bordeaux**, spécialisée dans **l'infogérance et la maintenance critique**.

- **Activité** : Pilotage d'infrastructures, gestion de parcs informatiques et cybersécurité pour les entreprises d'Aquitaine.
- **Enjeux** : Protection des données sensibles clients (accès privilèges, schémas réseau) et continuité d'activité.
- **Infrastructure** : Environnement virtualisé sous Proxmox incluant un Active Directory (WS 2019), un firewall OPNsense et une supervision Centreon.

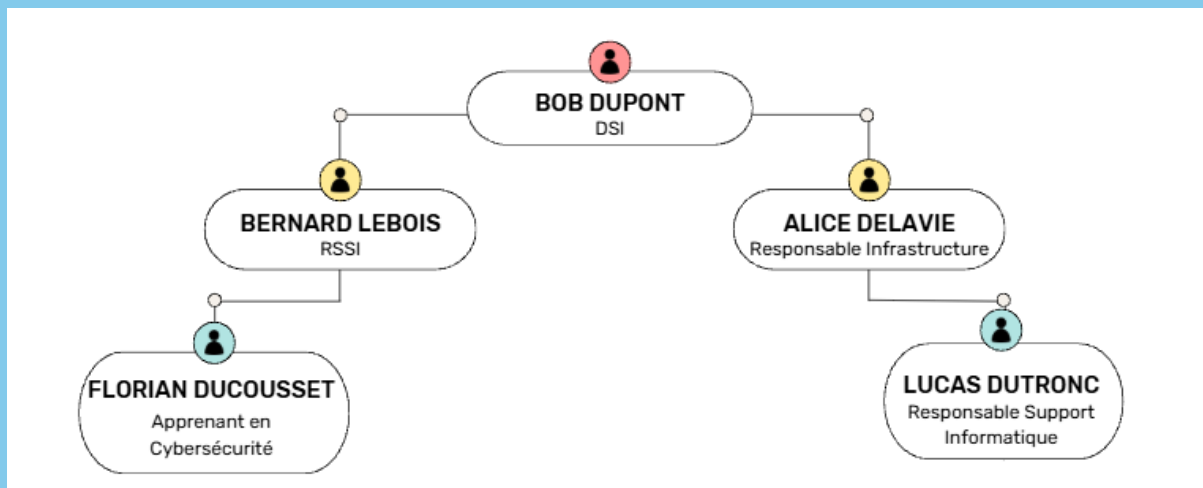
- **Déclencheur** : De récents nouveaux contrats exigent une mise en conformité réglementaire stricte notamment sur ANSSI + ISO 27001

2.2) Effectifs et organisation

L'entreprise compte aujourd'hui **5 collaborateurs** répartis en quatre pôles :

- **Pôle Technique (Production & Support)** : C'est le cœur de l'entreprise. Il regroupe les administrateurs système et réseau (Alice) et le support client (Lucas). Ils gèrent l'infrastructure Proxmox, l'Active Directory et l'assistance aux utilisateurs.
- **Pôle Cybersécurité** : Une unité dédiée aux audits de sécurité, à la mise en conformité OSE et à la remédiation (incluant le rôle de Bernard en tant que RSSI et Florian en support cyber)
- **Pôle Direction & Développement** : Porté par Bob (DSI), ce pôle définit la stratégie technologique et gère la relation avec les grands comptes et partenaires (OVH, éditeurs).
- **Pôle Administratif** : Également supervisé par Bob il assure la gestion de la facturation, des ressources humaines et du suivi des contrats de maintenance.

Tableau d'organisation du pôle SI :



2.3) Activité principale

L'offre de services de PROSECUREX s'articule autour de **trois axes majeurs** :

1. Infogérance et Solutions Cloud :

- **Hébergement haute disponibilité** : Plateformes sur mesure via l'infrastructure Proxmox.
- **Poste de travail moderne** : Déploiement et sécurisation de parcs Windows 10/11.
- **Services managés** : Gestion centralisée des identités via Active Directory.

2. Cybersécurité et Réseaux :

- **Protection périmétrique** : Mise en place et gestion du pare-feu OPNsense et segmentation DMZ.
- **Audit et Durcissement** : Analyses de vulnérabilités (PingCastle), remédiation et mise en conformité.
- **Accès distants sécurisés** : Accès sécurisé aux serveurs via des protocoles de communication chiffrés (**SSH**).

3. Monitoring :

- **Monitoring temps réel** : Surveillance des ressources des infrastructures via Centreon.

- **Détection d'incidents** : Analyse des journaux d'événements et alertes de sécurité.
- **Accompagnement critique** : Aide à la mise en place de stratégies de sauvegarde

4. Typologie des clients :

- **PME Industrielles** : Souhaitant sécuriser leur outil de production et limiter les risques d'attaques.
- **Acteurs de la Santé** : Cabinets médicaux et cliniques gérant des données patients hautement confidentielles.
- **Collectivités et OSE** : Structures bordelaises soumises à des obligations réglementaires de sécurité des données.

2.4) Enjeux métiers liés à l'informatique

L'activité de PROSECUREX repose **intégralement sur le numérique** :

Les enjeux majeurs identifiés sont :

- **Continuité de service** : Toute défaillance des infrastructures (Proxmox, OPNsense) paralyserait l'assistance aux clients et la surveillance des systèmes critiques.
- **Confiance et réputation** : La protection des accès privilèges et des configurations réseau des clients est vitale pour maintenir la crédibilité de l'entreprise.
- **Conformité réglementaire** : Le respect du RGPD et des exigences liées aux contrats est une condition non négociable pour son activité.
- **Intégrité des données** : Garantir que les sauvegardes et les annuaires (AD) ne sont pas exploitables par des menaces.
- **Résilience opérationnelle** : Savoir détecter et bloquer une attaque informatique est vital pour la continuité de l'entreprise
- **La cybersécurité est donc l'enjeu central de PROSECUREX** : Elle protège les données numériques de l'entreprise tout en

garantissant sa capacité à honorer ses engagements contractuels de haute sécurité.

2.5) Environnement technique général

L'infrastructure de PROSECUREX est une architecture hébergée sur un serveur OVH et pilotée par l'hyperviseur Proxmox.

Le parc informatique virtualisé se décompose de :

- **Gestion des Identités** : Un serveur "WINAD" sous Windows Server 2019, faisant office de contrôleur de domaine principal pour l'ensemble des ressources.
- **Poste Client** : 5 machines "WIN" (Windows 10/11) utilisée par les collaborateurs (Bob, Alice, Bernard, Lucas, Florian) pour accéder aux services de l'entreprise.
- **Supervision** : Un serveur CENTREON pour surveiller l'état de santé des équipements.
- **Sécurité & Filtrage** : Un pare-feu OPNSENSE assure le routage et la sécurité entre le WAN, le LAN et la DMZ.
- **Sauvegarde** : Les sauvegardes sont réalisées de manière manuelle et ponctuelle sur PROXMOX.

Afin d'assurer la **sécurité du réseau**, un pare-feu OPNsense est le pilier central de l'architecture. Il assure le filtrage du réseau.

Sous la gestion d'OPNsense, **deux zones réseau** ont été identifiées :

- **LAN** : Zone interne divisée en quatre parties. Elle héberge actuellement le contrôleur de domaine "WINAD", les postes utilisateurs "WIN", le serveur de supervision linux "CENTREON" ainsi que le pare-feu OPNsense. C'est l'espace de travail des collaborateurs
- **DMZ** : Zone isolée configurée sur OPNsense pour accueillir à terme les services exposés ou de monitoring. Bien que l'interface soit prête, elle reste vide à ce jour.

Enfin, la partie sauvegarde est assurée sur le **serveur Proxmox** situé dans les locaux de PROSECUREX à Bordeaux. Les snapshots des VM hébergées y sont synchronisés **quotidiennement**, garantissant une reprise rapide d'activité **en cas d'incident majeur**.

Cette architecture offre un équilibre **optimal et simple**, grâce à l'utilisation de solutions **open-source et à faible cout** (Proxmox, OPNsense, Centreon, OPNsense).

3) Cahier des charges de l'audit

3.1) Expression du besoin initial

PROSECUREX a fait l'obtention de **nouveaux contrats** avec de grosses sociétés, donc cela impose de garantir un niveau de sécurité **supérieur aux standards habituels**. L'entreprise doit s'assurer que son architecture **respecte strictement** les bonnes pratiques de **l'ANSSI et l'ISO 27001**.

L'audit est donc sollicité pour :

- **Identifier les vulnérabilités critiques** : Vérifier le niveau de sécurité et les failles potentiels sur l'ensemble de l'infrastructure.
- **Valider la segmentation réseau** : Vérifier l'étanchéité et les accès entre les différentes zones de l'infrastructure.
- **Évaluer la conformité** : Mesurer l'écart entre l'existant et les recommandations de l'ANSSI et l'ISO 27001.
- **Sécuriser les identités** : Analyser la gestion des privilèges des utilisateurs pour limiter les risques de mouvement latéral.

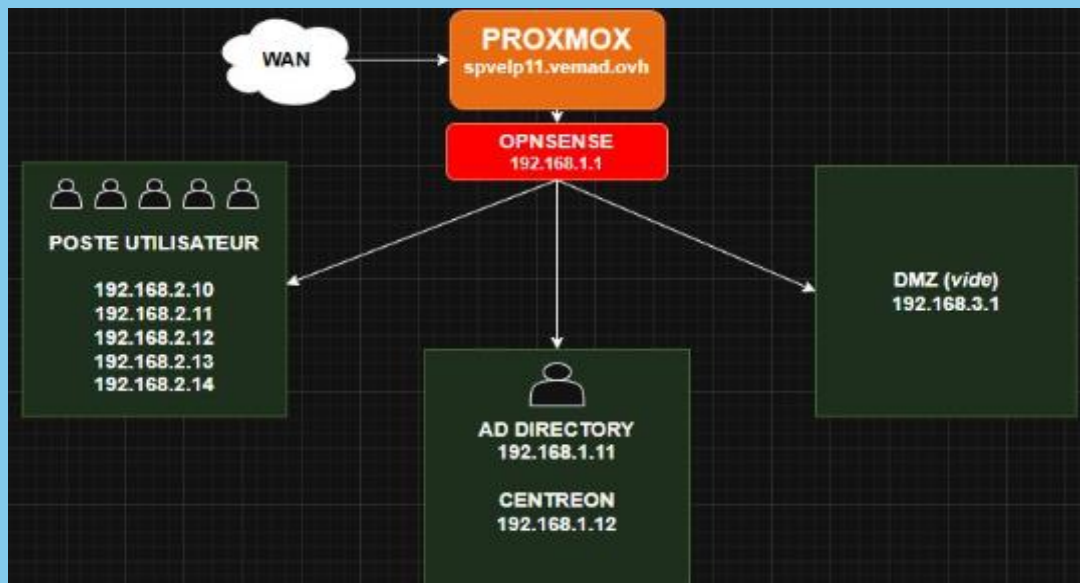
- **Proposer un plan de remédiation** : Définir des actions concrètes adaptées aux ressources d'une PME.

3.2) Objectifs spécifiques

L'audit se concentre sur les **contrôle logique-organisationnel** afin de valider la robustesse de l'architecture en matière de sécurité :

- **Sécurité de Proxmox** : Évaluer la configuration, la gestion des accès à l'interface d'administration et la politique de mise à jour des machines virtuelles
- **Configuration du pare-feu OPNSENSE** : Contrôler la pertinence des règles de filtrage au sein du réseau.
- **Étanchéité de la segmentation** : Analyser la communication entre les différentes zones de l'infrastructure pour vérifier qu'aucun "rebond" n'est possible.
- **Audit de l'Active Directory** : Analyser les potentiels vulnérabilités critiques et vérifier la configuration générale. De plus une utilisation de l'outil "PINGCASTLE" en complément.
- **Supervision** : Vérifier que le serveur Centreon remonte correctement les informations sur les ressources de l'entreprise.
- **Résilience et Sauvegarde** : Évaluer la fiabilité des snapshots et identifier les risques liés à la gestion manuelle des sauvegardes.
- **Plan de remédiation** : Proposer des mesures concrètes pour renforcer la sécurité

3.3) Périmètre de l'audit



ACTIF	Nom d'hôte	Rôle	Système d'exploitation	IP
Hyperviseur	Proxmox	Hôte de virtualisation	Debian	spvelp11.vemad.ovh
Contrôleur de domaine	WINAD	Gestion de l'ensemble des ressources	Windows Server 2019	192.168.1.11/24
Poste Utilisateur	WIN	Poste de travail (Bob/Alice/Lucas /Florian/Bernard)	Windows 10/11	192.168.2.10/24 192.168.2.11/24 192.168.2.12/24 192.168.2.13/24 192.168.2.14/24
Pare-feu - OPNsense	FWOPNSENSE	Filtrage réseau	FreeBSD	192.168.1.1/24
Supervision IT - Centreon	LINSUP	Monitoring et Alerting	Linux	192.168.1.12/24
DMZ	(Aucun – zone vide)	Zone exposée au public	FreeBSD	192.168.3.1/24

3.4) Contraintes techniques et organisationnelles

Pour mener à bien cet audit les contraintes suivantes ont été définies :

- **Disponibilité du service** : En absence de LAB, l'audit doit être réalisé sans aucune interruption des services critiques.
- **Validation des accès** : Toute intervention sur les serveurs est préalablement validée par l'administrateur système référent (Alice).

- **Limites budgétaires et ressources** : En tant que PME, PROSECUREX privilégie les solutions Open-Source et des recommandations à faible coût.
- **Confidentialité** : L'auditeur est soumis à une clause de confidentialité stricte concernant les schémas réseau et les données clients stockés sur l'infrastructure.

3.5) Livrables attendus

À l'issue de la mission, l'auditeur remettra à la direction de PROSECUREX les documents suivants :

1. Rapport d'audit technique complet :

- **État des lieux détaillé** : Analyse général de l'infrastructure Proxmox, de la configuration de l'AD, de la supervision CENTREON, de la gestion des postes utilisateurs et du pare-feu OPNsense.
- **Cartographie réseau actualisée** : Schéma précis des différentes zones.
- **Analyse de vulnérabilités** : Identification des failles (PingCastle & manuel) classées par criticité (0-1-2-3) avec preuves techniques à l'appui.
- **Évaluation de conformité** : Comparaison de l'existant avec les référentiels ANSSI et l'ISO 27001.
- **Recommandations** : Solutions logique et organisationnel.

2. Plan d'action priorisé

Le plan de remédiation est construit en **quatre niveau** pour une gestion efficace des risques :

- **Priorité 0 (Immédiat)** : Actions de sécurisation critiques réalisées durant l'audit
- **Priorité 1 (Urgent)** : Mesures à appliquer dès la restitution du rapport
- **Priorité 2 (Court terme)** : Correction à court terme
- **Priorité 3 (Moyen terme)** : Actions d'amélioration continue et de renforcement.

3.6) Matrice de responsabilité

Taches	DSI	INFRA	SUPPORT	RSSI	APPRENANT
Collecte d'information réseaux et AD	I	C	C	I	R
AUDIT PingCastle	I	C		A	R
AUDIT AD	I	C		A	R
Audit OPNsense	I	C		A	R
Règles segmentation réseaux	I	C		C	R
AUDIT Centreon	I	C	I		R
Audit Proxmox	I	A		I	R
Audit sauvegarde	I	C		C	R
Remédiation de sécurisation	I	C	C	A	R
Rédaction rapport	I	C		A	R

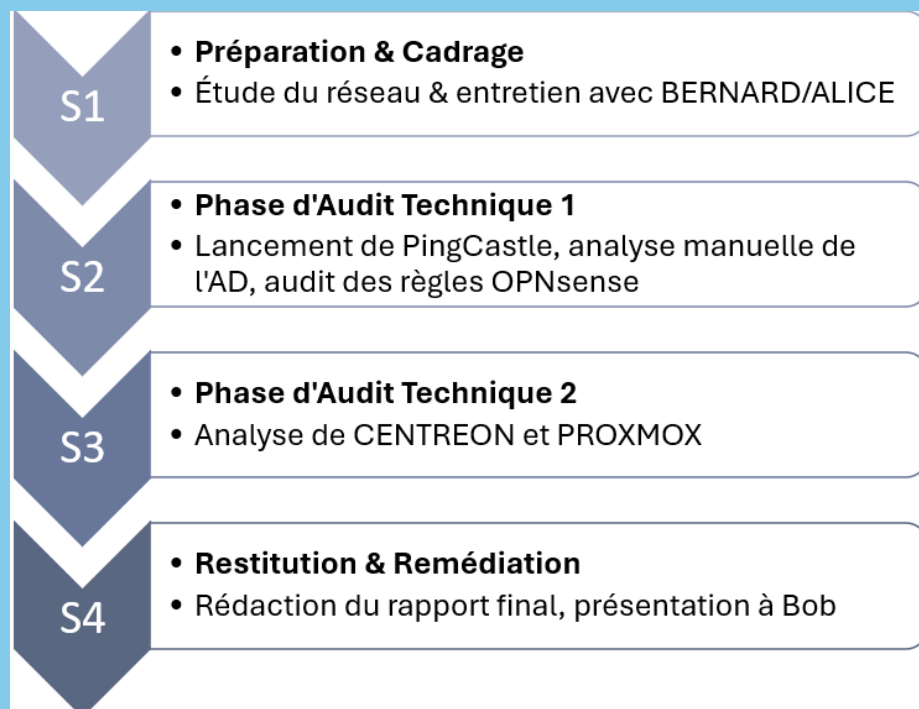
Légende du tableau RACI :

R – Réalisateur	Personne qui réalise concrètement la tâche
A – Approbateur	Personne qui valide le travail et en porte la responsabilité finale
C – Consulté	Experts ou référents techniques à qui l'on demande des informations pour mener à bien la mission
I – Informé	Personne qui est tenu au courant de l'avancement ou des résultats de la tâche

3.7) Durée et calendrier de l'audit

L'audit s'est déroulé sur une période de **4 semaines**, alternant phases d'observation, tests techniques et rédaction de préconisations. Cette durée a permis de **respecter les contraintes de production** de PROSECUREX tout en **garantissant une analyse profonde** de l'ensemble de l'infrastructure.

Phasage du projet :



4) Méthodologie

4.1) Méthode de collecte des données

Pour cet audit, j'ai utilisé **deux méthodes** complémentaires :

- **Observations passives** : Analyse des schémas réseau fournis par Alice et lecture des configurations existantes sur l'ensemble de l'infrastructure.
- **Entretiens techniques** : Échanges avec Bernard (RSSI) pour comprendre les exigences de sécurité et avec Lucas (Support) pour identifier les problèmes rencontrés par les utilisateurs.

4.2) Outils utilisés

Durant l'AUDIT j'ai **utilisé les outils** suivants :

Analyse de l'Active Directory (WINAD) :

- **PingCastle** : Outil d'audit automatique permettant de détecter des vulnérabilités existantes sur l'AD.
- **Gestionnaire de serveur** : Utilisation de l'ensemble des menus du "gestionnaire de serveur", mais plus particulièrement "Utilisateurs et ordinateurs AD" et de "l'Éditeur de gestion des GPO" pour l'analyse manuelle.

Gestion et observation de l'infrastructure :

- **Interfaces de gestion** : Ensemble des menus et règles dans OPNsense et de Centreon.
- **Hyperviseur Proxmox** : Analyse de la configuration matérielle des machines virtuelles et vérification des snapshots.

4.3) Référentiels suivis

L'audit s'appuie sur des standards reconnus en matière de sécurité :

- **Guide de l'ANSSI** : Prise en compte des règles de base pour évaluer le niveau de sécurité minimal de l'infrastructure
- **ISO 27001** : Référentiel technique des exigences pour gérer et améliorer continuellement l'infrastructure.
- **Référentiel RNCP37680BC03 – Bloc 3** : Compétence liées à la gestion de la cybersécurité (mesure, politique, traitement des incidents).

4.4) Politique d'échantillonnage

L'ensemble de l'infrastructure a été considéré dans le périmètre.

Toutefois, les tests approfondis ont été concentrés sur :

Comptes Utilisateurs :

- 100 % des comptes actifs présents dans l'Active Directory ont été audités.
- Objectif : Vérifier individuellement pour chaque collaborateur la robustesse du mot de passe et l'appartenance aux groupes de sécurité. Cela permet de garantir qu'aucun compte "orphelin" ou en surplus existe.

Serveurs et Machines Virtuelles :

- Focus sur le contrôleur de domaine, le serveur de supervision Centreon et le pare-feu OPNsense de manière générale.
- Objectif : Ces machines sont les piliers du SI, leur compromission paralyserait l'entreprise.

Flux Réseau :

- Cibles : Analyse poussée de l'ensemble des règles de filtrage de OPNsense.

4.5) Limites de l'audit

Bien que cet audit **couvre les piliers majeurs de l'infrastructure**, certaines zones ont été volontairement **exclues du périmètre** pour des raisons de **temps, de sécurité ou de moyens techniques** :

- **Audit physique et environnemental** : L'accès physique général aux locaux n'ont pas été évalués.
- **Tests d'intrusion** : Aucune tentative d'exploitation réelle de vulnérabilité n'a été menée. L'objectif était d'identifier les failles et non de les utiliser, afin de ne pas risquer d'interrompre les services.
- **Ingénierie sociale** : Aucun test de phishing ou de manipulation n'a été effectué auprès des collaborateurs pour tester leur vigilance.
- **Analyse du code source** : L'audit s'est concentré sur la configuration des services et des systèmes, et non sur la sécurité interne.
- **Absence de SIEM (Wazuh)** : Comme précisé précédemment, l'absence actuelle d'un outil de centralisation des logs limite l'audit à une analyse "statique" plutôt qu'à une analyse comportementale sur la durée.

4.6) Déroulement général de l'audit

L'audit a été découpée en **quatre phases** majeures pour garantir l'analyse :

Phase de Cadrage :

- Réunions de lancement avec Bernard (RSSI) et Alice (Responsable Infra).
- Récupération des accès d'administration et des schémas réseau.
- Définition précise du périmètre

Phase d'Investigation Technique (Collecte) :

- Exécution des outils automatisés (PingCastle).

- Analyses manuelles de l'ensemble de l'AD.
- Vérification générale des règles et configuration de l'OPNsense, de CENTREON et PROXMOX.

Phase d'Analyse et de Corrélation :

- Étude des rapports générés par PINGCASTLE pour éliminer les faux positifs.
- Vérification de la cohérence entre la politique théorique et la réalité technique
- Test de la capacité de retour arrière via les snapshots.

Phase de Synthèse et Restitution :

- Classification des vulnérabilités par niveau de criticité (de "Faible" à "Critique").
- Élaboration du plan de remédiation avec des solutions concrètes.
- Présentation des résultats à Bob (DSI) pour validation des futures actions.

5) Audit d'infrastructure

5.1) Politique de sécurité existante

Points Positifs (L'existant fonctionnel) :

- **Centralisation des identités** : L'utilisation de l'Active Directory permet une bonne gestion des sessions et des droits des collaborateurs
- **Segmentation réseau** : La mise en place d'OPNsense comme pilier central permet de filtrer les flux entre le WAN et le LAN, limitant l'exposition directe sur Internet.
- **Protection de base des terminaux** : L'activation de Windows Defender sur l'ensemble des postes utilisateurs assure une

première barrière contre les malwares connus sans surcoût de licence.

- **Surveillance active** : La présence de Centreon permet de remonter des alertes de disponibilité sur les actifs critiques.
- **Sécurité de l'annuaire** : La Corbeille Active Directory est activée, permettant une restauration rapide et intègre des objets en cas de suppression accidentelle, sans interruption de service.

Points Négatifs (Les faiblesses identifiées)

- **Absence de PSSI** : Il n'existe aucun document définissant les règles générales en matière de sécurité de l'infrastructure
- **Politique de mot de passe** : Les mots de passe de l'ensemble des services et utilisateurs sont trop simples ou identiques sur plusieurs services.
- **Défaut de segmentation réelle** : Bien que prévue, la zone DMZ reste vide, laissant le serveur de supervision dans le même segment que le contrôleur de domaine.
- **Processus de sauvegarde** : Le caractère manuel et ponctuel des sauvegardes expose l'entreprise à une perte de données importante en cas d'oubli ou d'attaque.
- **Absence de centralisation des logs (SIEM)** : L'entreprise utilise Centreon, qui est un outil de métrologie (disponibilité CPU, RAM, Ping), mais elle ne dispose d'aucune solution comme Wazuh pour l'analyse des journaux d'événements
- **Manque de sensibilisation à la cybersécurité** : Les collaborateurs n'ont reçu aucune formation sur les risques numériques basique.

5.2) Analyse de la gestion des risques

L'analyse suivante repose sur l'identification des couples **Menaces/Vulnérabilités**. Chaque risque est évalué selon son impact sur les données de PROSECUREX.

Menace	Vulnérabilité	Risque Identifié	Priorité (0-3)
Intrusion	Manque de segmentations	Risque de rebond	1
Sauvegarde	Processus de sauvegarde manuel et ponctuel	Risque d'indisponibilité	1
Attaque par Force Brute	Mots de passe identiques ou trop simples	Risque d'usurpation	0
Logiciel Malveillant	Absence de centralisation des logs	Risque de non-détection	0
Erreur Humaine	Manque de sensibilisation des collaborateurs	Risque d'exécution	2

Explications **détaillées** des risques majeurs :

1. Le Risque de Rebond :

Le fait que l'ensemble de l'infrastructure soit mal segmenté (WAN-LAN-DMZ) crée un "pont" direct. Si l'interface web de Centreon (souvent exposée pour la consultation) est piratée, l'attaquant est déjà à l'intérieur du réseau d'administration. Il n'a plus de barrière pour atteindre l'AD.

2. Le Risque d'Indisponibilité :

Dans une architecture pro, la sauvegarde doit être "automatique et déportée" et établi sur des plans. Le mode manuel actuel repose sur la mémoire du technicien. Si un incident survient le vendredi et que la dernière sauvegarde date du lundi, l'entreprise perd 4 jours de travail.

3. Le Risque de Non-Détection :

L'absence de Wazuh est critique. Centreon surveille si le serveur "vit". Mais si un attaquant crée un nouvel utilisateur administrateur sur l'AD à 2h du matin, Centreon ne dira rien. Sans système de logs centralisé, PROSECUREX est "aveugle" face aux événements de sécurité.

4. Le Facteur Humain :

Même avec le meilleur pare-feu du monde, si un employé clique sur une fausse facture reçue par mail, le virus est téléchargé derrière le pare-feu. Le manque de sensibilisation transforme chaque poste de travail en une porte d'entrée potentielle.

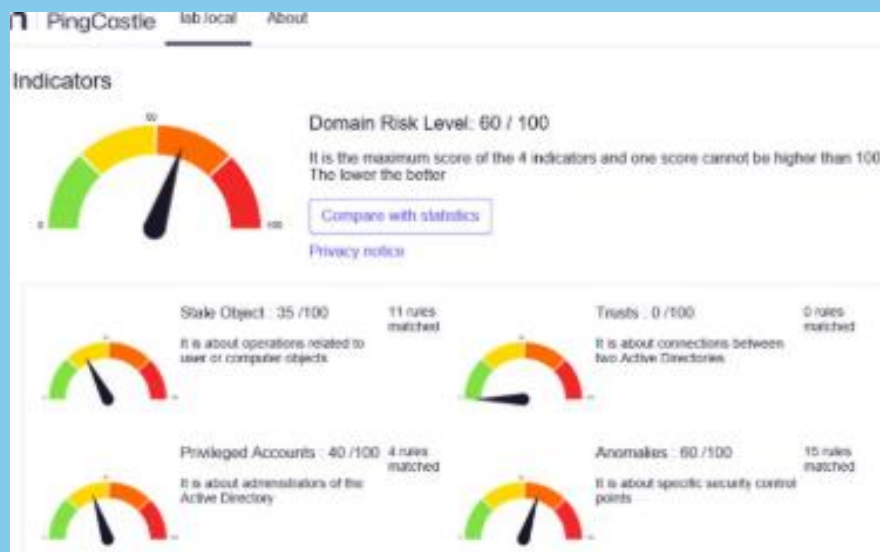
5.3) Identification des actifs sensibles

Actif critique	Criticité
AD	Maximale (P1)
OPNSENSE	Haute (P2)
PROXMOX	Haute (P2)
CENTREON	Moyenne (P3)

- **Pourquoi l'AD Directory** : C'est le cœur de l'authentification. S'il tombe ou est piraté, plus aucun employé ne peut travailler ou accéder aux fichiers
- **Pourquoi OPNsense** : C'est le "gardien" de l'infrastructure. S'il est hors service, l'entreprise n'a plus d'accès Internet et les segments ne peuvent plus communiquer
- **Pourquoi Proxmox** : C'est l'assurance vie de PROSECUREX. En cas de compromission sur le serveur OVH, c'est le seul moyen de restaurer l'activité sans perdre l'historique.
- **Pourquoi Centreon** : Il permet de détecter les pannes. Sans lui, l'administrateur est "aveugle" et mettra plus de temps à réagir en cas d'incident technique.

5.4) Menaces et vulnérabilités

Afin d'évaluer la robustesse du domaine, un audit automatisé a été réalisé avec l'outil **PingCastle**. Cet outil, préconisé par l'ANSSI, permet de **mesurer le niveau de risque** de l'annuaire selon quatre indicateurs clés.

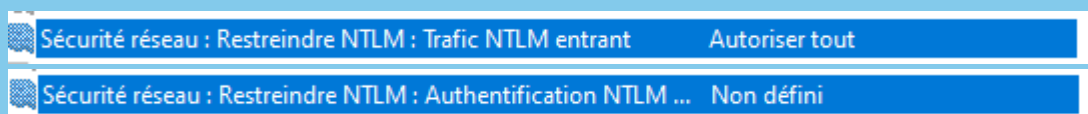


Analyse du rapport d'audit :

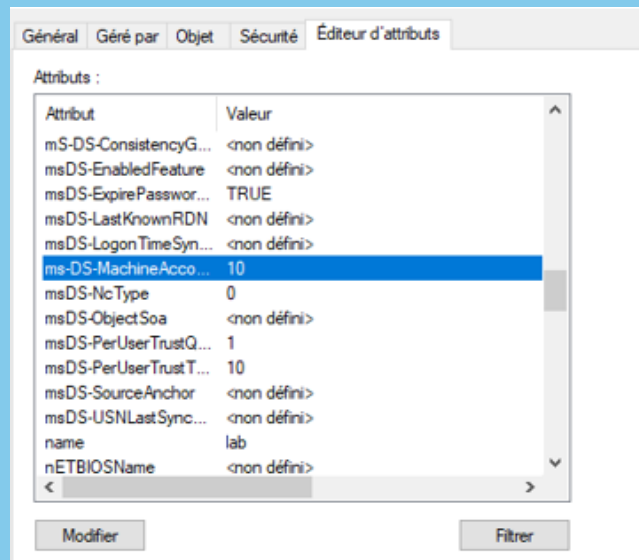
Le score de risque global obtenu est de **60/100**. Plus ce score est élevé, plus le domaine est vulnérable. Les points d'attention relevés sont :

- **Objets obsolètes :**

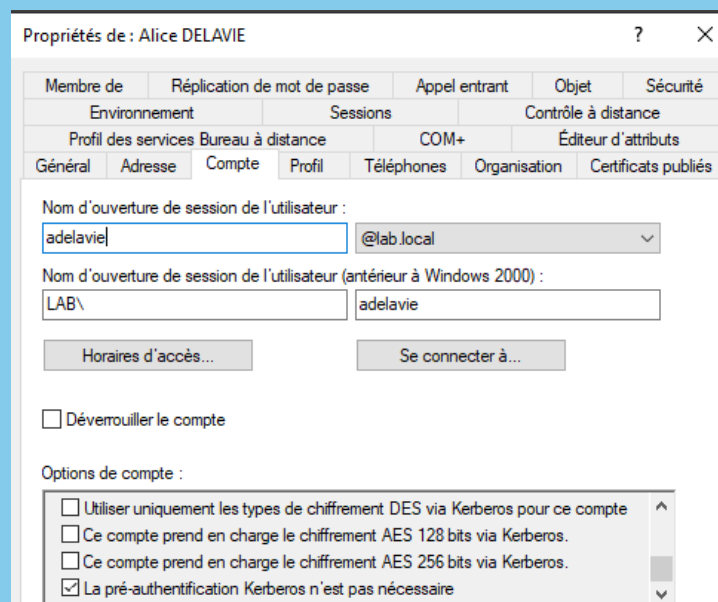
NTLM : Utilisation de protocoles d'authentification anciens et vulnérables aux attaques par interception.



Droit d'ajout de machines : Les utilisateurs non-administrateurs peuvent ajouter jusqu'à 10 ordinateurs au domaine, ce qui peut être exploité pour créer des machines malveillantes.

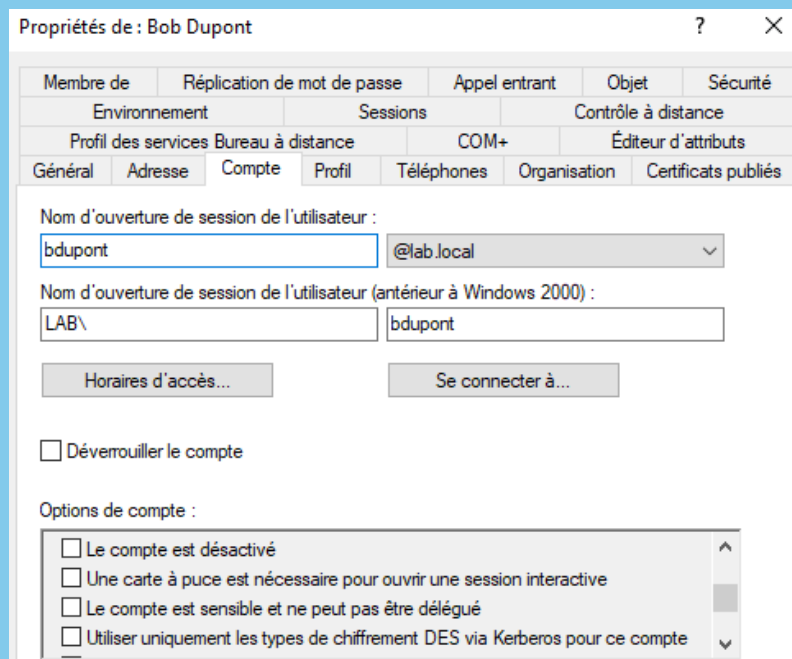


Kerberos : Un utilisateur est configuré sans pré-authentication Kerberos, ce qui l'expose directement à des attaques de vol de hash de mot de passe.

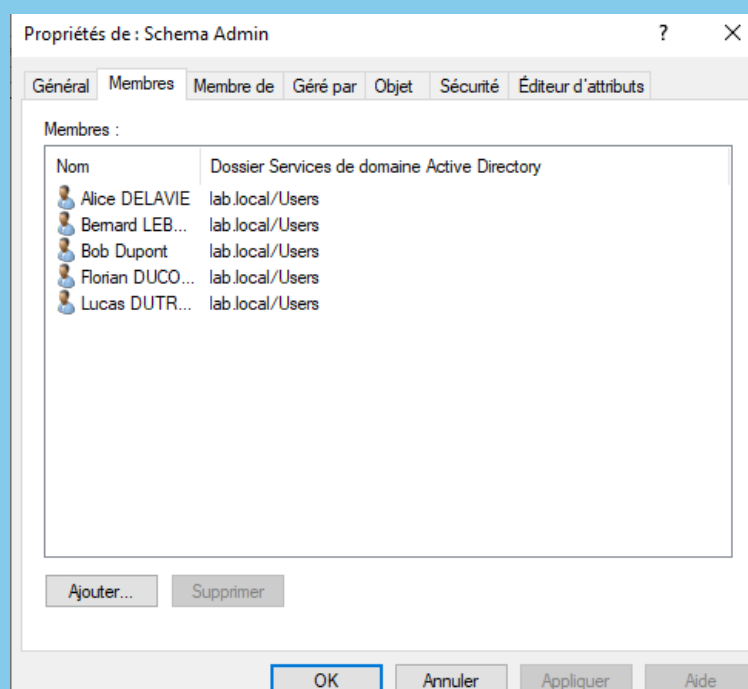


- **Comptes à hauts privilèges :**

Défaut de délégation : 6 comptes administrateurs ne possèdent pas l'option "Ce compte est sensible et ne peut être délégué", facilitant le vol de jetons d'accès.



Groupe Schéma Admin : Ce groupe très critique n'est pas vide, ce qui est contraire aux bonnes pratiques



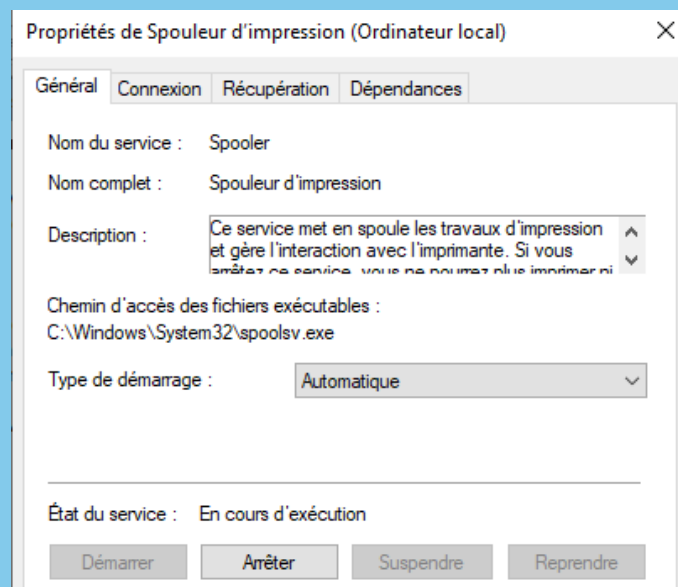
- **Anomalies :**

Absence de LAPS : Les mots de passe des administrateurs locaux ne sont pas gérés de manière dynamique, ce qui facilite la compromission d'un compte administrateur local.

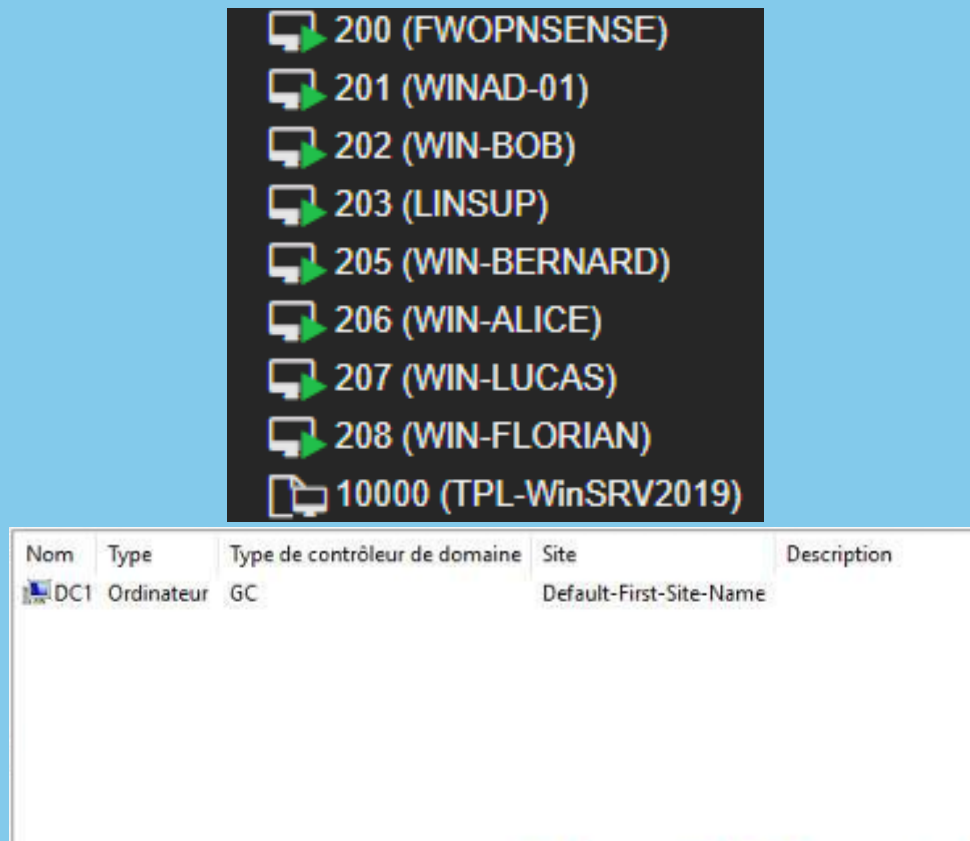
Politique de mots de passe : La politique n'est pas à jour et mal configuré, rendant les comptes vulnérables aux attaques par dictionnaire.

Stratégie	Paramètres de stratégie
Conserver l'historique des mots de passe	24 mots de passe mémorisés
Durée de vie maximale du mot de passe	90 jours
Durée de vie minimale du mot de passe	1 jours
Enregistrer les mots de passe en utilisant un chiffrement rév...	Désactivé
Le mot de passe doit respecter des exigences de complexité	Désactivé
Longueur minimale du mot de passe	6 caractère(s)

Service Spooler : Le service d'impression est actif sur le contrôleur de domaine et accessible à distance.



Résilience : Le nombre de contrôleurs de domaine est de 1, cela est trop faible pour garantir la haute disponibilité.



The image shows a network scanner interface. At the top, a list of hosts is displayed with computer icons and green arrows indicating connectivity. Below this, a table lists Active Directory objects.

Nom	Type	Type de contrôleur de domaine	Site	Description
DC1	Ordinateur	GC	Default-First-Site-Name	

- **Trust Relationship :**

Aucune vulnérabilité détectée sur cet indicateur

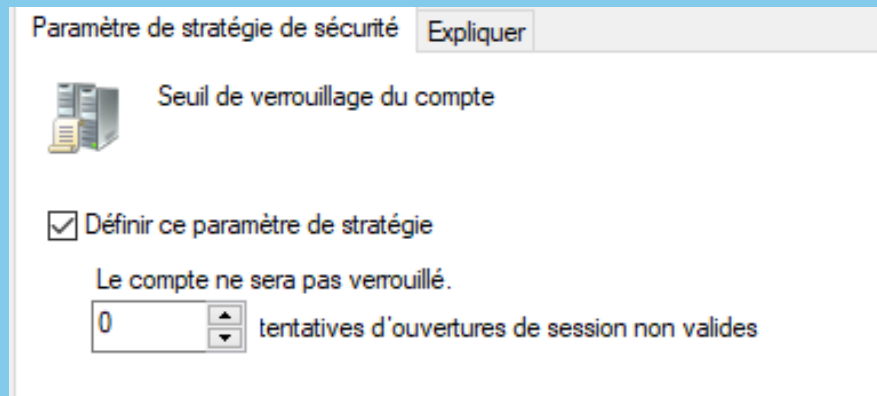
5.4.2) Focus : Audit de l'Active Directory (Analyse Manuelle)

En complément de l'outil PingCastle, **un audit technique approfondi a été réalisé manuellement** sur l'Active Directory :

A. Failles de la politique de Sécurité :

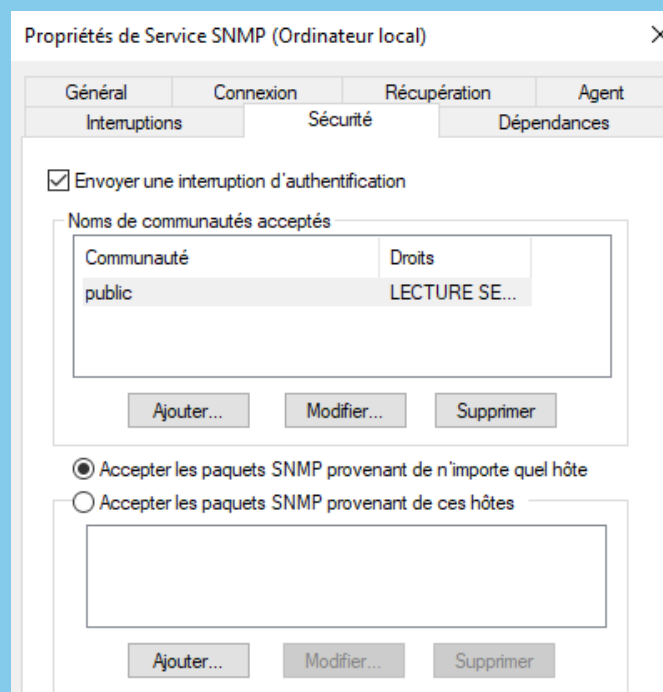
- **Verrouillage de compte :** Le seuil de verrouillage n'est pas configuré. Un attaquant peut mener une attaque par force brute

illimitée sans que le compte ne soit bloqué après 5 tentatives par exemple.



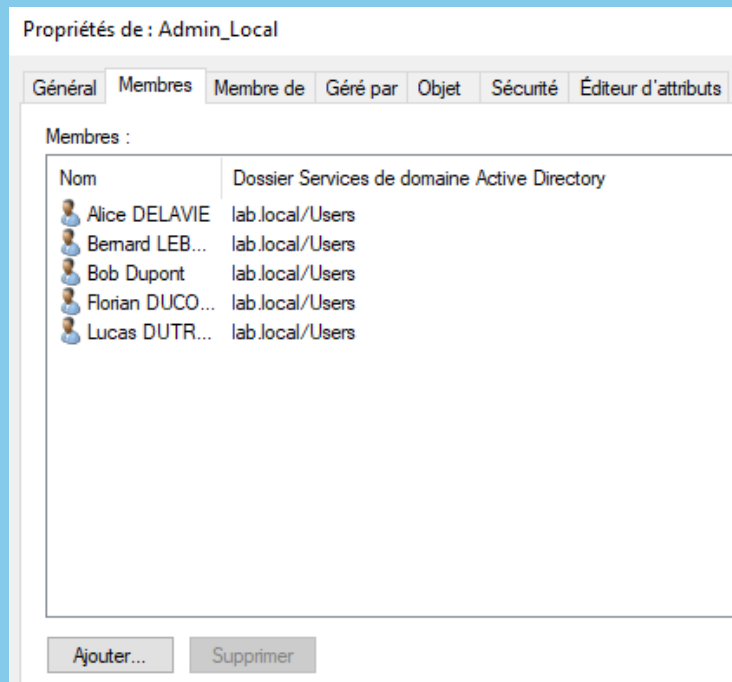
B. Exposition et Outils d'Attaque :

- **Configuration SNMP critique :** Le service accepte les paquets de "n'importe quel hôte" avec la communauté "public". Cela permet à n'importe qui d'émettre un scan sur un équipement sur le réseau et de voler des informations sensibles de l'AD.

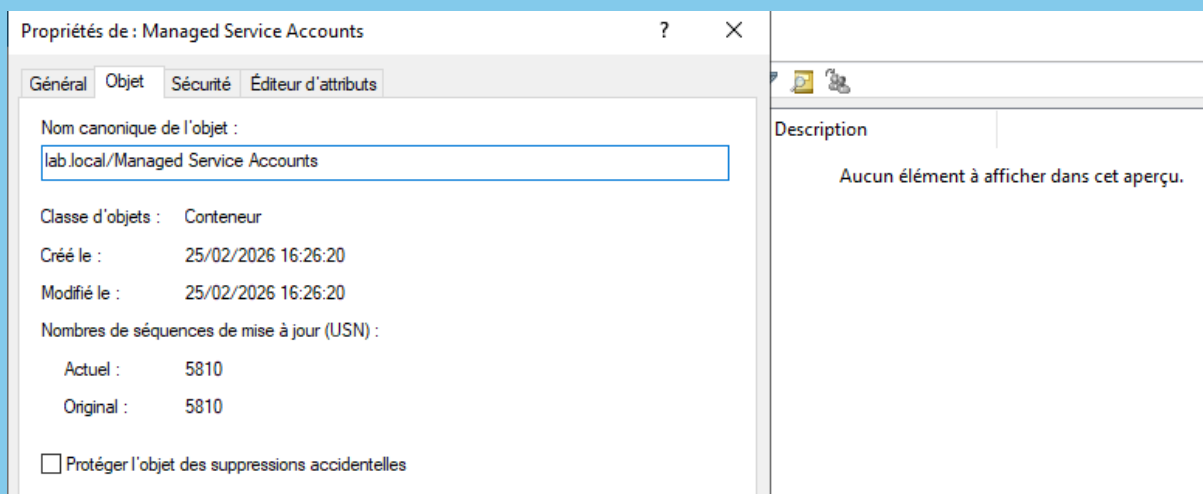


C. Gestion des Privilèges et Administration :

- **Privilèges excessifs (Admin Local) :** Tous les utilisateurs possèdent des droits d'administrateur local sur leurs postes. Cela permet l'installation de logiciels non autorisés et facilite la désactivation de l'antivirus ou l'extraction de mots de passe.



- **Groupe de service :** Usage de comptes de service standards au lieu de GMSA, augmentant le risque d'attaques de type Golden Ticket.



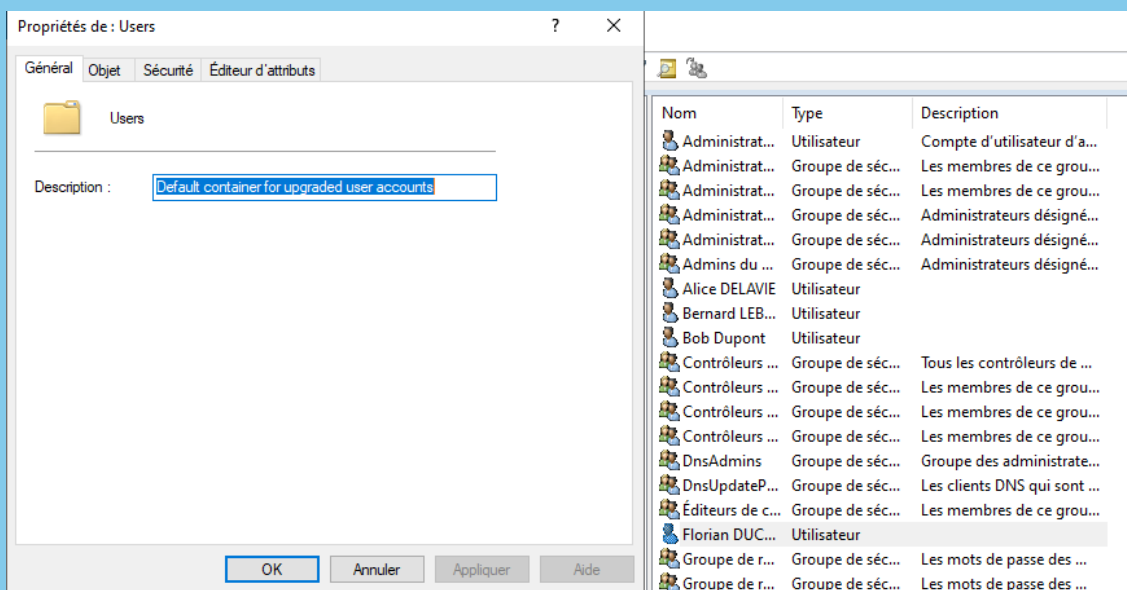
- **Interface Web exposée :** L'accès à l'interface de gestion d'OPNsense est possible depuis tous les postes utilisateurs.

- **Compte Administrateur :** Le compte "Administrateur" par défaut est toujours actif et utilisé, au lieu d'utiliser des comptes nominatifs.

Nom	Type	Description
Administrat...	Utilisateur	Compte d'utilisateur d'a...
Administrat...	Groupe de séc...	Les membres de ce grou...
Administrat...	Groupe de séc...	Les membres de ce grou...
Administrat...	Groupe de séc...	Administrateurs désigné...
Administrat...	Groupe de séc...	Les membres qui ont un...

D. Structure et Environnement :

- **Absence de segmentation logique :** Tous les utilisateurs sont regroupés dans un seul et même groupe, ne respectant pas le cloisonnement par métier.

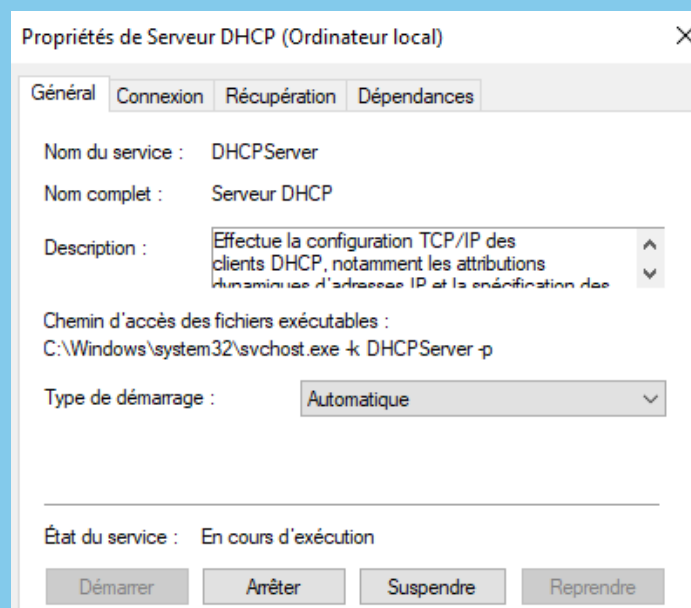


- **Absence d'environnement de test (LAB) :** Toute modification est faite directement en production, au risque de corrompre l'annuaire lors d'une mise à jour ou d'un changement de configuration.

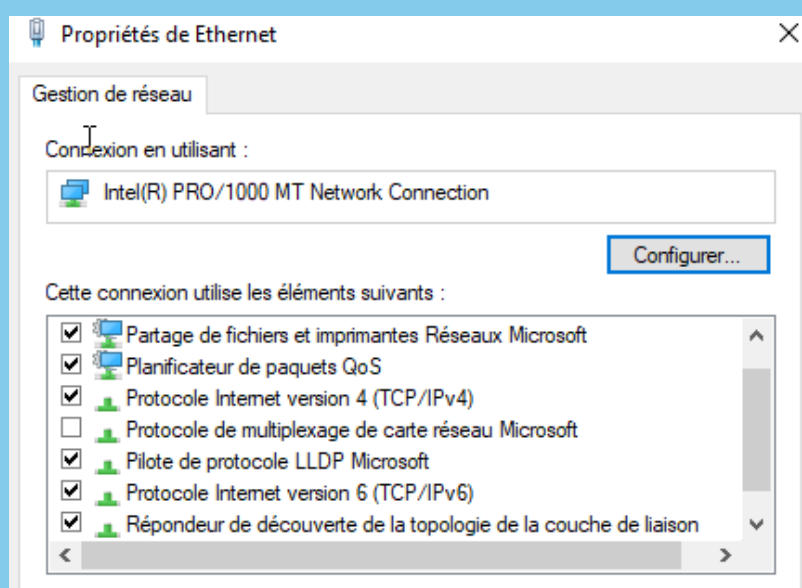
E. Services Réseau et Protocoles :

- **Service DHCP sur le Contrôleur de Domaine :** Le rôle DHCP est actuellement porté par le serveur AD, En cas de compromission

du serveur AD, l'attaquant peut manipuler les baux DHCP pour rediriger le trafic



- **Le protocole IPv6 :** Il est activé par défaut sur l'ensemble du domaine et des postes utilisateurs, alors que l'infrastructure est exclusivement configurée en IPv4. Un attaquant peut exploiter l'IPv6 des postes utilisateurs sans qu'aucune alerte ne soit levée en IPv4. Cela permet de voler des identifiants Windows très facilement



5.4.3) Audit technique de la solution de supervision (Centreon)

La plateforme de supervision Centreon, bien que **fonctionnelle** pour la remontée d'alertes, présente des **failles de sécurité critiques** liées à son installation et à sa configuration initiale :

A. Gestion des secrets et fuites d'informations

- **Mots de passe en clair** : Présence du fichier "generated.tobesecured" dans les répertoires d'installation. Ce fichier contient les identifiants de root pour la base de données

```
[root@LINSUP ~]# cat /etc/centreon/generated.tobesecured  
Random password generated for user [Database user: root] is [fuA7d@ZQ*S!49x2R]
```

- **Comptes par défaut** : Utilisation du compte utilisateur "centreon" avec un mot de passe par défaut ou simple pour l'accès à la base de données.

B. Emplacement réseau et cloisonnement :

- **Défaut de segmentation** : Le serveur Centreon et OPNsense est situé dans le même segment réseau que le contrôleur de domaine.

ACTIF	Nom d'hôte	Rôle	Système d'exploitation	IP
Hyperviseur	Proxmox	Hôte de virtualisation	Debian	spvelp11.vemad.ovh
Contrôleur de domaine	WINAD	Gestion de l'ensemble des ressources	Windows Server 2019	192.168.1.11/24
Poste Utilisateur	WIN	Poste de travail (Bob/Alice/Lucas /Florian/Bernard)	Windows 10/11	192.168.2.10/24 192.168.2.11/24 192.168.2.12/24 192.168.2.13/24 192.168.2.14/24
Pare-feu	OPNSENSE	Filtrage réseau	FreeBSD	192.168.1.1/24
Supervision	CENTREON	Monitoring et Alerting	Linux	192.168.1.12/24
DMZ	(Aucun – zone vide)	Zone exposée au public	FreeBSD	192.168.3.1/24

D. Maintien en condition de sécurité :

- **Absence de durcissement** : L'OS (Linux) ne dispose pas de restriction d'accès SSH par clé privée (utilisation du mot de passe uniquement).

```
# Authentication:
#PasswordAuthentication yes
#PermitEmptyPasswords no
#LoginGraceTime 2m
#PermitRootLogin prohibit-password
```

- **Gestion des mots de passe** : Absence de politique de complexité. Les mots de passe sont faibles et aucune rotation n'est imposée.

E. Sécurité de l'accès à l'administration :

- **Compte privilégié root** : Le compte super-utilisateur root est actif et utilisé pour l'administration quotidienne via l'interface Web. Un attaquant connaît déjà le nom d'utilisateur à cibler. En cas de compromission de ce compte, l'attaquant a un contrôle total et irréversible sur tout le trafic réseau

```
[root@LINSUP ~]# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
```

5.4.4) Audit technique du Pare-feu (OPNsense)

L'analyse de la configuration d'OPNsense montre une **mise en place fonctionnelle** mais des **lacunes importantes** en termes de cloisonnement réel et de **durcissement** :

A. Segmentation Réseau et Interfaces :

- **DMZ Inactive** : Bien qu'une interface vtnet3 (192.168.3.1/24) soit créée et activée, elle reste vide. Les services exposés (Centreon) stagnent dans le LAN, rendant la segmentation théorique mais non appliquée.

Interfaces: [DMZ]

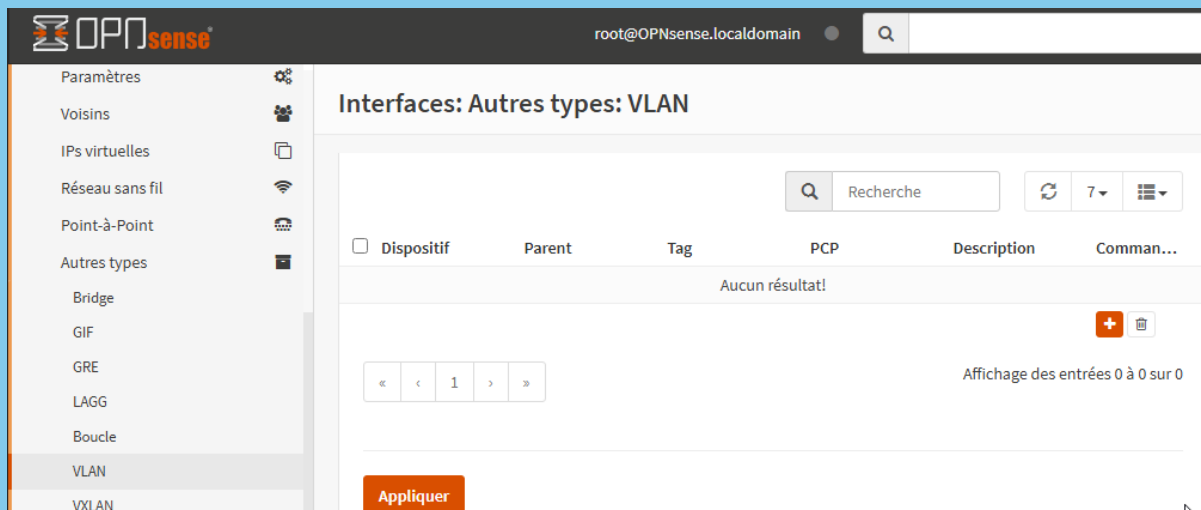
Configuration de base

Activer	☒ Activer l'interface
Verrouiller	☐ Empêcher la suppression de l'interface
Identifiant	opt2
Dispositif	vtnet3
Description	DMZ

Configuration générique

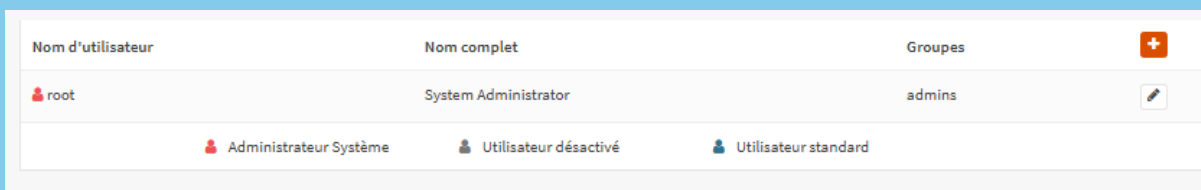
Bloquer les réseaux privés	☐
Bloquer les adresses bogon (non attribuées par l'IANA)	☐
Type de configuration IPv4	Adresse IPv4 statique
Type de configuration IPv6	Aucun

- **Absence de VLANs** : L'utilisation d'interfaces physiques/virtuelles séparées est correcte, mais l'absence de segmentation VLANs au sein des zones est très dangereux.



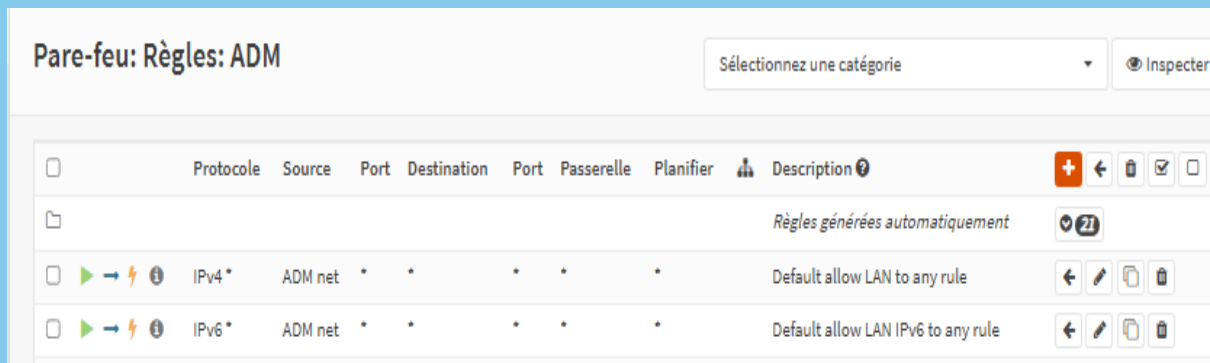
B. Accès et Administration :

- **Interface Web exposée** : L'accès à l'interface de gestion d'OPNsense est possible depuis les postes utilisateurs.
- **Absence de Double Authentification** : L'accès à l'administration du pare-feu repose uniquement sur un mot de passe local, sans validation supplémentaire, ce qui est risqué pour l'équipement central de sécurité.
- **Connexion avec l'utilisateur root** : L'accès à l'interface de gestion se fait avec l'utilisateur root.

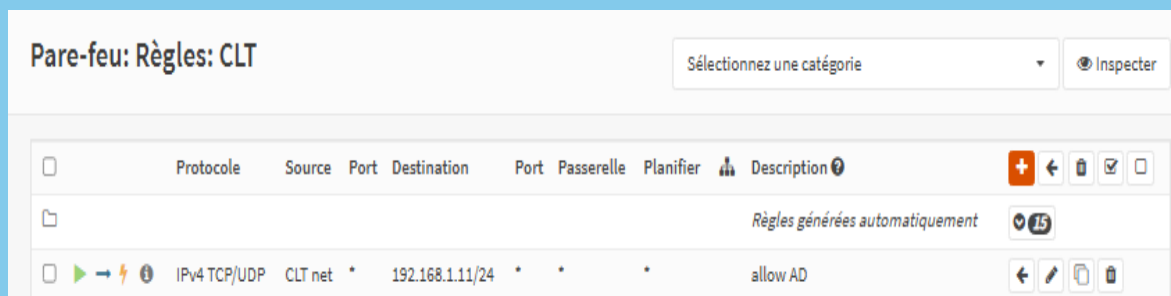


C. Analyse des règles de filtrage :

- **Interface Administration/LAN** : Une règle "Default allow LAN to any rule" en IPv4 et IPv6 est présente. Si un attaquant prend la main sur un poste de ce réseau, il peut scanner l'intégralité de l'infrastructure et exfiltrer des données sans être bloqué par le pare-feu.



- **Interface poste utilisateurs :** La règle autorise tout le trafic TCP/UDP de CLT net vers l'IP 192.168.1.11. Un utilisateur malveillant sur le segment Client peut tenter d'attaquer des services sensibles sur le serveur AD qui ne devraient pas lui être accessibles



5.4.5) Audit technique de l'hyperviseur (Proxmox)

L'hyperviseur Proxmox présente une **base saine et sécurisée**, mais souffre d'un **manque de formalisation** qui pourrait paralyser l'exploitation en cas **d'absence de l'administrateur** principal :

A. Déficit de documentation :

- **Défaut de nommage et de métadonnées :** Les noms des VMs (ex: LINSUP) ne sont pas assez explicites et ne sont accompagnés d'aucune note de description dans l'interface Proxmox. Si un intervenant externe ou un nouveau collaborateur

doit intervenir, il ne peut pas identifier rapidement le rôle critique de chaque serveur, ce qui augmente le temps de résolution en cas de panne

- **Absence de Plan de Sauvegarde :** La protection des données repose sur des snapshots déclenchés ponctuellement par l'humain. Il n'existe aucun PCA/PRA, ce mode de fonctionnement est jugé "inapproprié" pour une infrastructure de production. En cas d'erreur humaine ou de corruption de données entre deux snapshots manuels, la perte d'informations pourrait être irréversible

The image displays three screenshots of the OpenStack dashboard, specifically the 'Sauvegarde' (Backup) section for three different virtual machines. Each screenshot shows a table of backups with columns for Name, Notes, Date, Format, and Size.

Machine virtuelle 200 (FWOPNSENSE) sur le nœud ns3223506

Nom	Notes	Date ↓	Format	Taille
vzdump-qemu-200-2026_04_11-16_44_47.vma.zst	Save_OPNSENSE	2026-04-11 16:44:47	vma.zst	713.41 Mo

Machine virtuelle 203 (LINSUP) sur le nœud ns3223506

Nom	Notes	Date ↓	Format	Taille
vzdump-qemu-203-2026_04_11-16_43_50.vma.zst	Save LINSUP	2026-04-11 16:43:50	vma.zst	2.06 Go

Machine virtuelle 201 (WINAD) sur le nœud ns3223506

Nom	Notes	Date ↓	Format	Taille
vzdump-qemu-201-2026_04_11-16_39_31.vma.zst	Save AD_Directory	2026-04-11 16:39:31	vma.zst	9.17 Go

5.5) Organisation de sécurité

A. Absence de cadre formel (PSSI)

L'audit révèle l'**absence de Politique de Sécurité des Systèmes d'Information (PSSI)** . Actuellement, la sécurité n'est pas régie par un document de référence, mais repose sur une gestion "**au fil de l'eau**" par l'administrateur système. Cette approche **empêche le maintien d'un niveau de sécurité** homogène sur l'ensemble de l'infrastructure.

B. Déficit de contrôle et de conformité

L'organisation actuelle **souffre d'un manque de processus** de vérification :

- **Revue de comptes inexistantes** : Aucun audit périodique des droits n'est réalisé. Cette absence de contrôle explique pourquoi certains utilisateurs disposent de privilèges administratifs excessifs sans justification.
- **Contrôle de conformité** : Il n'existe aucun mécanisme permettant de vérifier que les serveurs respectent les bonnes pratiques de configuration sur le long terme.

5.6) Rôles et responsabilités

A. Cumul des fonctions techniques

- **Le constat** : On observe un cumul de responsabilités important au niveau de l'administration. La gestion du réseau, de la sécurité et des systèmes est centralisée entre les mains d'un seul intervenant, sans mécanismes de double contrôle.
- **Risque** : Cette absence de séparation des tâches augmente la probabilité d'erreurs de configuration non détectées et rend le SI vulnérable si ce compte unique est compromis.

B. Droits excessifs

- L'audit des postes de travail révèle que les utilisateurs disposent de droits "Administrateur Local".
- **Le constat** : Cette pratique contrevient au principe du "Moindre Privilège". Trop d'utilisateurs possèdent des droits qu'ils ne devraient pas avoir pour leurs tâches quotidiennes.
- **Impact sur l'imputabilité** : En cas d'incident (suppression de fichiers critiques, installation d'un logiciel malveillant, modification système), il devient impossible de déterminer avec certitude l'origine de l'action. Cette situation complique toute analyse post-incident.

5.7) Plan de continuité et de reprise d'activité (PCA / PRA)

L'audit révèle une **fragilité critique** concernant la **survie des données** en cas d'incident majeur :

- **PCA (Plan Continuité Activité)** : Inexistant. L'infrastructure repose sur un serveur Proxmox unique. Une panne matérielle entraînerait l'arrêt immédiat de tous les services.
- **PRA (Plan Reprise Activité)** : Fragile. La sauvegarde repose sur des snapshots manuels déclenchés par l'administrateur.
- **Risques (RTO/RPO)** :

Perte de données (RPO) : Potentiellement plusieurs jours de travail perdus si aucun snapshot récent n'a été fait.

Délai de relance (RTO) : Inconnu, car aucune procédure de restauration n'est documentée ni testée.

Constat : En cas d'attaque ou de panne disque, la reprise d'activité serait lente et incomplète.

5.8) Gestion des incidents

- **Détection** : Dépendance exclusive à Centreon. Si l'outil est aveuglé ou compromis, la panne n'est pas détectée.
- **Réaction** : Absence de procédure de crise. La gestion des pannes se fait dans l'urgence, sans étapes prédéfinies pour isoler ou analyser une menace.

5.9) Formation et sensibilisation

- **Facteur humain** : Aucune action de sensibilisation à la cybersécurité.
- **Conséquence** : Les utilisateurs ont des pratiques à risque (mots de passe simples) aggravées par leurs privilèges d'administrateurs locaux.

6) Audit technique

6.1) Cartographie technique

À la suite de l'audit, l'infrastructure a été **réorganisée pour isoler les services critiques** et clarifier les rôles de chaque machine. La cartographie repose désormais sur une **segmentation en 5 zones distinctes** gérées par le pare-feu/router OPNsense :



6.2) Diagramme Réseau et Matrice de flux

A. Tableau de l'architecture cible :

VLAN 10	ADMIN	BOB / ALICE / BERNARD / FLORIAN
VLAN 20	SUPPORT	LUCAS
VLAN 30	DMZ	WAZUH / CENTREON
VLAN 40	AD	AD-01
VLAN 50	CDS	CDS-02

B. Matrice de flux :

Source	Destination	Protocole / Port	Justification
Toutes zones	Wazuh	TCP 1514 / 1515	Remontée des logs vers SIEM
Zone admin	Toutes zones	HTTPS/SSH/RDP	Administration et audit
Admin & Support	AD01-CDS	DNS/LDAP/KERBEROS	Authentification et services
AD-01	CDS	RPC / DFSR	Réplication critique
Support	WAN	HTTP / HTTPS	Recherche de solutions
DMZ / AD01-CDS	Admin	BLOQUE	Interdiction stricte remontée

6.3) Mise en œuvre technique de l'infrastructure

A. Connexion à l'interface de gestion :

- Le compte root a été désactivé, un nouvel utilisateur a été créé pour gérer l'administration d'OPNsense.

Système: Accès: Utilisateurs			
Nom d'utilisateur	Nom complet	Groupes	
admin-OPNSENSE		admins	 

B. Segmentation réseau et Virtualisation (VLANs)

Pour isoler les flux sans multiplier les équipements physiques, j'ai mis en place des VLANs sur l'interface OPNsense.

- **Action** : Création de 5 interfaces virtuelles (VLAN 10, 20, 30, 40, 50).
- **Objectif** : Étanchéité totale entre la zone ADMIN, SUPPORT, AD, CDS, DMZ.

Interfaces: Autres types: VLAN						
☐ Dispositif	Parent	Tag	PCP	Description	Comman...	
☐ vlan01	vtnet0 (bc:24:11...	10	Au mieux (0, val...	ZONE_ADMIN	  	
☐ vlan02	vtnet0 (bc:24:11...	20	Au mieux (0, val...	ZONE_SUPPORT	  	
☐ vlan03	vtnet3 (bc:24:11...	30	Au mieux (0, val...	ZONE_DMZ	  	
☐ vlan04	vtnet0 (bc:24:11...	40	Au mieux (0, val...	ZONE_AD	  	
☐ vlan05	vtnet0 (bc:24:11...	50	Au mieux (0, val...	ZONE_CDS	  	

C. Services d'adressage et de résolution (DHCP & DNS)

Le rôle de serveur DHCP a été confié à l'OPNsense.

- **DHCP** : Configuration de 5 étendues IP distinctes. Chaque zone possède sa propre plage d'adresses et sa passerelle dédiée.

- **DNS** : L'OPNsense a été configuré pour rediriger les requêtes vers les contrôleurs de domaine (AD-01 et CDS), garantissant ainsi la résolution des noms du domaine.

Services: ISC DHCPv4: [ZONE_ADMIN]
[aide complète](#)

? Activer
☒ Activer le serveur DHCP sur l'interface ZONE_ADMIN

! Refuser les clients inconnus
☐

! Ignorer les UID des clients
☐

? Sous-réseau
192.168.10.0

? Masque de sous-réseau
255.255.255.0

? Plage disponible
192.168.10.1 - 192.168.10.254

? Plage

de
à

192.168.10.1
192.168.10.150

Services: ISC DHCPv4: [ZONE_SUPPORT]
[aide complète](#)

? Activer
☒ Activer le serveur DHCP sur l'interface ZONE_SUPPORT

! Refuser les clients inconnus
☐

! Ignorer les UID des clients
☐

? Sous-réseau
192.168.20.0

? Masque de sous-réseau
255.255.255.0

? Plage disponible
192.168.20.1 - 192.168.20.254

? Plage

de
à

192.168.20.100
192.168.20.200

Modifier l'alias

Activé ☒

Nom PORTS_WAZUH

Type Port(s)

Catégories

Contenu 1514 x 1515 x

Tout effacer Copie Pâte

Description

Modifier l'alias

Activé ☒

Nom PORTS_AD

Type Port(s)

Catégories

Contenu 53 x 88 x 389 x 445 x 636 x

Tout effacer Copie Pâte

Description

- **Sécurité sortante** : Les serveurs AD et la DMZ sont restreints dans leurs accès vers l'extérieur pour limiter les fuites de données ou les mises à jour non contrôlées.

E. Tests et validation de la connectivité

Une phase de tests a été réalisée pour valider le cloisonnement :

- **Test de communication** : Vérification du succès des flux entre le VLAN 10 (ADMIN) et le VLAN 40 (AD).
- **Test d'isolation** : Vérification de l'échec des pings depuis le VLAN 30 (DMZ) vers le VLAN 10 (ADMIN).

Pare-feu: Règles: ZONE_ADMIN

Sélectionnez une catégorie

Inspect

La configuration des règles du pare-feu a été modifiée.
 Vous devez appliquer les modifications afin qu'elles prennent effet.

Appliquer les changements

	Protocole	Source	Port	Destination	Port	Passerelle	Planifier	Description	
								Règles générées automatiquement	15
☐	IPv4 TCP	ZONE_ADMIN net	*	Ce Pare-feu	443 (HTTPS)	*	*	ACCES INTERFACE WEB FIREWALL	
☐	IPv4 TCP	ZONE_ADMIN net	*	ZONE_AD net	3389 (MS RDP)	*	*	ACCES BUREAU DISTANCE	
☐	IPv4 TCP	ZONE_ADMIN net	*	ZONE_DMZ net	80 - 443	*	*	CONSULTATION DASHBOARD	
☐	IPv4 *	ZONE_ADMIN net	*	*	*	*	*	ACCES INTERNET	

Pare-feu: Règles: ZONE_SUPPORT

Sélectionnez une catégorie

Inspect

La configuration des règles du pare-feu a été modifiée.
 Vous devez appliquer les modifications afin qu'elles prennent effet.

Appliquer les changements

	Protocole	Source	Port	Destination	Port	Passerelle	Planifier	Description	
								Règles générées automatiquement	15
☐	IPv4 TCP	ZONE_SUPPORT net	*	192.168.30.2/24	PORTS_WAZUH	*	*	Flux Agents WAZUH	
☐	IPv4 TCP/UDP	ZONE_SUPPORT net	*	ADM net	PORTS_AD	*	*	Autoriser Auth AD	
☐	IPv4 TCP	ZONE_SUPPORT net	*	ZONE_AD net	3389 (MS RDP)	*	*	INTERDIRE RDP VERS AD	
☐	IPv4 *	ZONE_SUPPORT net	*	IP_PROXMOX	*	*	*	BLOCAGE HYPERVISEUR	
☐	IPv4 *	ZONE_SUPPORT net	*	WAN net	*	*	*	AUTORISATION WEB	

Pare-feu: Règles: ZONE_DMZ

Sélectionnez une catégorie

Inspecter

La configuration des règles du pare-feu a été modifiée.
Vous devez appliquer les modifications afin qu'elles prennent effet.

Appliquer les changements

	Protocole	Source	Port	Destination	Port	Passerelle	Planifier	Description	
								Règles générées automatiquement	15
	IPv4 TCP	ZONE_DMZ net	*	192.168.30.2/24	PORTS_WAZUH *	*		LOGS WAZUH	
	IPv4 TCP	ZONE_DMZ net	*	*	443 (HTTPS)	*		AUTORISER MAJ CENTREON	
	IPv4 *	ZONE_DMZ net	*	IP_PROXMOX *	*	*		BLOPAGE HYPERVISEUR	
	IPv4 *	ZONE_DMZ net	*	ZONE_AD net	*	*		INTERDIRE DMZ VERS AD	
	IPv4 *	ZONE_DMZ net	*	ZONE_ADMIN net	*	*		INTERDIRE DMZ A ADMIN	

première

Pare-feu: Règles: ZONE_AD

Sélectionnez une catégorie

Inspecter

La configuration des règles du pare-feu a été modifiée.
Vous devez appliquer les modifications afin qu'elles prennent effet.

Appliquer les changements

	Protocole	Source	Port	Destination	Port	Passerelle	Planifier	Description	
								Règles générées automatiquement	15
	IPv4 TCP	ZONE_AD net	*	192.168.30.2/24	PORTS_WAZUH *	*		Logs WAZUH AD	
	IPv4 TCP/UDP	ZONE_AD net	*	*	*	*		REPONSE DNS ET AUTHENTIFICATION	
	IPv4 *	ZONE_AD net	*	IP_PROXMOX *	*	*		BLOPAGE VERS HYPERVISEUR	
	IPv4 *	ZONE_AD net	*	ZONE_DMZ net	*	*		VEROUILLAGE AD VERS SUPERVISION	
	IPv4 *	ZONE_AD net	*	WAN net	*	*		INTERDIRE INTERNET VERS AD	

première

Pare-feu: Règles: ZONE_CDS

Sélectionnez une catégorie

Inspecter

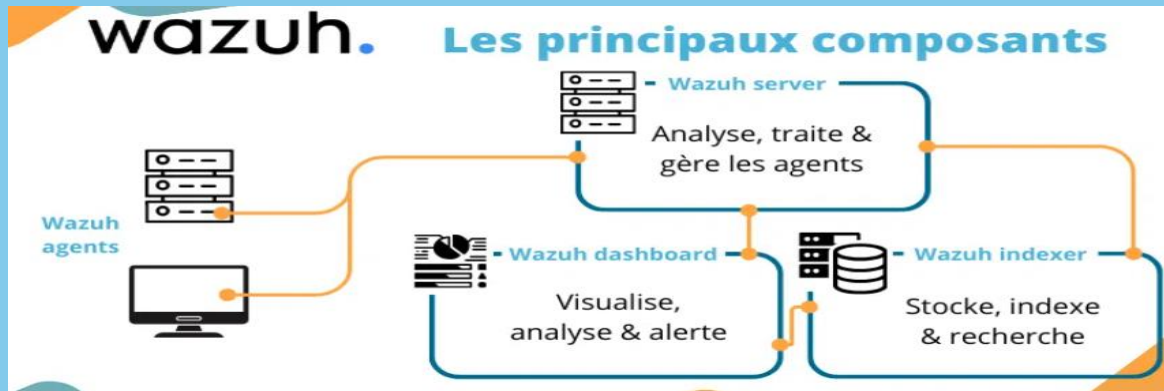
La configuration des règles du pare-feu a été modifiée.
Vous devez appliquer les modifications afin qu'elles prennent effet.

Appliquer les changements

	Protocole	Source	Port	Destination	Port	Passerelle	Planifier	Description	
								Règles générées automatiquement	15
	IPv4 TCP	ZONE_CDS net	*	192.168.30.2/24	PORTS_WAZUH *	*		LOGS WAZUH CDS	
	IPv4 UDP	ZONE_CDS net	*	*	161 (SNMP)	*		SUPERVISION COLLECTE SNMP	
	IPv4 TCP	ZONE_CDS net	*	*	443 (HTTPS)	*		AUTORISER MAJ LINUX	
	IPv4 *	ZONE_CDS net	*	IP_PROXMOX *	*	*		BLOPAGE HYPERVISEUR	
	IPv4 *	ZONE_CDS net	*	ZONE_AD net	*	*		INTERDIRE ACCES DIRECT AD	

6.4) Services exposés

Wazuh a été choisi pour **centraliser les journaux d'événements** et détecter les **comportements suspects** :



- **Installation de l'Agent** : Un agent a été déployé sur chaque poste de travail et sur les contrôleurs de domaine.
- **Flux de remontée** : Les agents communiquent vers le serveur situé en DMZ via les ports 1514 et 1515.
- **Sécurité** : Le serveur Wazuh est "passif", il reçoit les données mais n'a pas l'autorisation d'initier de connexion vers les machines des utilisateurs.

Monitoring et Disponibilité (Centreon) :

Pour garantir que l'infrastructure est opérationnelle, une solution Centreon surveille l'état de santé des équipements.

- **Indicateurs surveillés** : Taux d'utilisation CPU, espace disque restant sur les AD, et état des interfaces réseau sur l'OPNsense.

Accès à l'interface de gestion :

L'accès aux tableaux de bord de ces services est restreint :

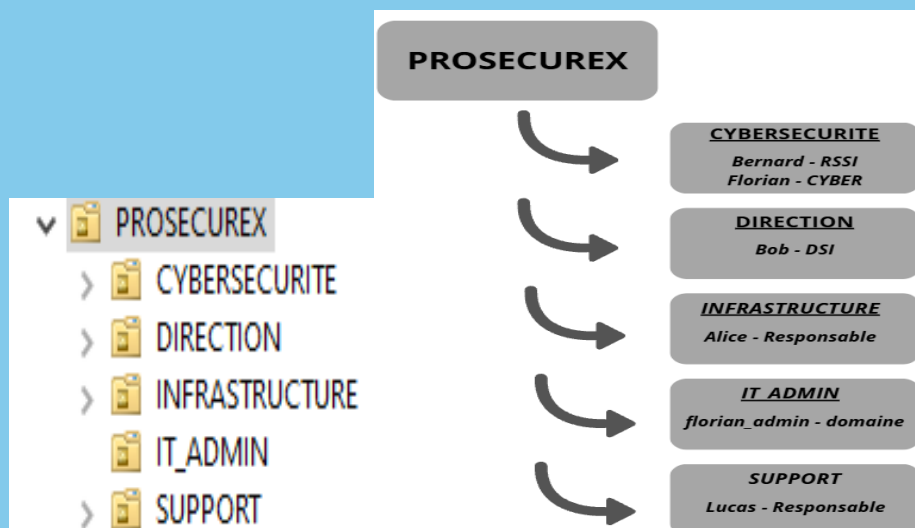
- **Filtrage IP** : Seules les adresses IP provenant du VLAN 10 (ADMIN) peuvent accéder aux interfaces Web de Wazuh et Centreon (Port 443).
- **Authentification** : L'accès est protégé par des comptes nominatifs avec des mots de passe robustes.

6.5) Active Directory

L'Active Directory a été **configuré comme le pilier de la sécurité**, en appliquant des **principes de durcissement pour limiter** la surface d'attaque.

A. Architecture de l'annuaire (OU et Groupes)

- **Unités d'Organisation (OU)** : Séparation stricte entre OU_CYBERSECURITE, OU_DIRECTION, OU_INFRASTRUCTURE, OU_IT_ADMIN et OU_SUPPORT pour appliquer des politiques de groupe (GPO) différenciées. De plus un utilisateur "florian-admin" a été créé pour gérer le domaine de manière isolé.



- **Groupes de Sécurité** : Utilisation du modèle de délégation pour que les permissions ne soient jamais attribuées directement à un utilisateur, mais via des groupes.

B. Durcissement des Stratégies de Mots de Passe (GPO)

La "Default Domain Policy" a été modifiée pour imposer des règles strictes:

- **Complexité** : 12 caractères minimum, historique de 5 mots de passe mémorisés avec la complexité des exigences activée.

- **Cycle de vie** : Durée maximale de 30 jours et minimale de 1 jour.

Stratégie	Paramètres de stratégie
Conserver l'historique des mots de passe	5 mots de passe mémorisés
Durée de vie maximale du mot de passe	30 jours
Durée de vie minimale du mot de passe	1 jours
Enregistrer les mots de passe en utilisant un chiffrement rév...	Désactivé
Le mot de passe doit respecter des exigences de complexité	Activé
Longueur minimale du mot de passe	12 caractère(s)

- **Sécurité des comptes** : Désactivation du compte "Administrateur" par défaut au profit de comptes nominatifs...

Nom	Type	Description	
Administrat...	Utilisateur	Compte d'utilisateur d'a...	
Administrat...	Groupe de séc...	Les membres de ce grou...	Copier...
Administrat...	Groupe de séc...	Les membres de ce grou...	Ajouter à un groupe...
Administrat...	Groupe de séc...	Administrateurs désigné...	Mappages des noms...
Administrat...	Groupe de séc...	Les membres qui ont un...	Activer le compte

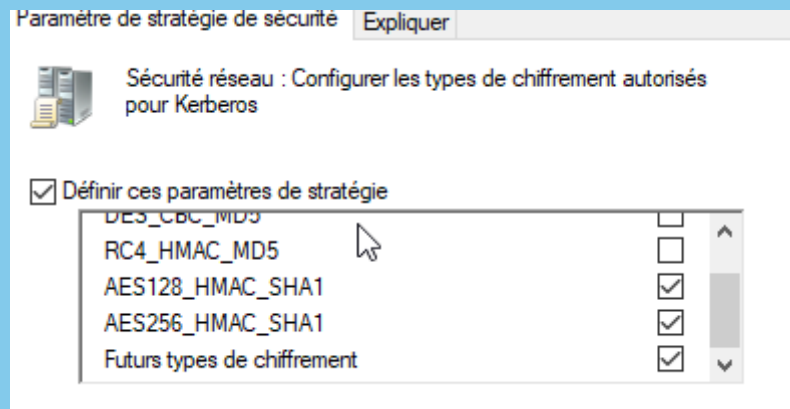
C. Sécurisation des Protocoles d'Authentification

Pour contrer les attaques de type Pass-the-Hash ou Relay, les protocoles obsolètes ont été neutralisés :

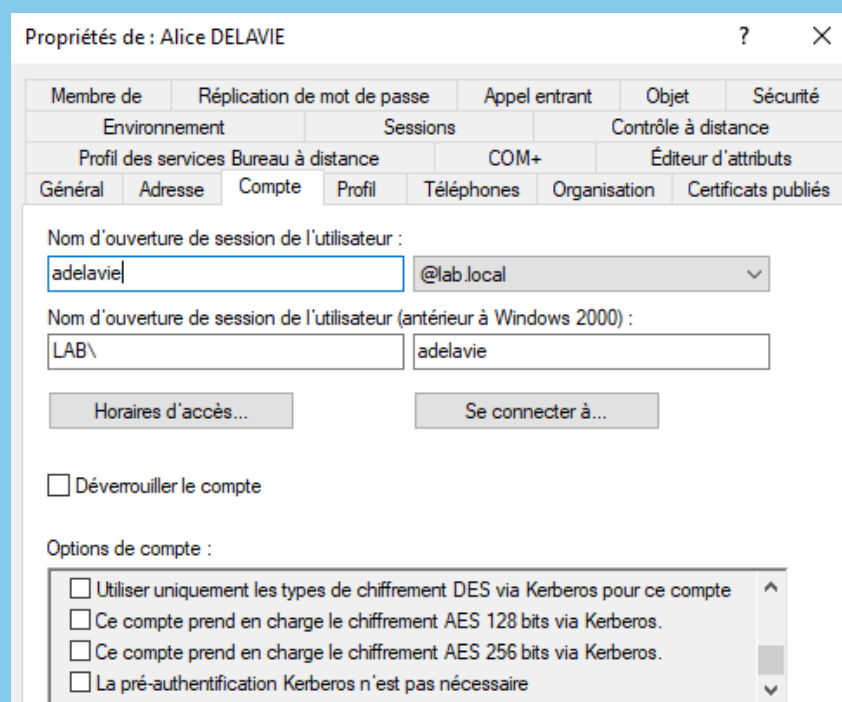
- **Désactivation de NTLM** : Forçage de Kerberos pour toutes les authentifications réseau.

Sécurité réseau : Restreindre NTLM : Trafic NTLM entrant	Refuser tous les comptes
Sécurité réseau : Restreindre NTLM : Authentification NTLM ...	Non défini

- **Chiffrement Kerberos** : Configuration pour n'autoriser que l'AES128 et l'AES256 et futur type de chiffrement, interdisant les suites de chiffrement vulnérables.

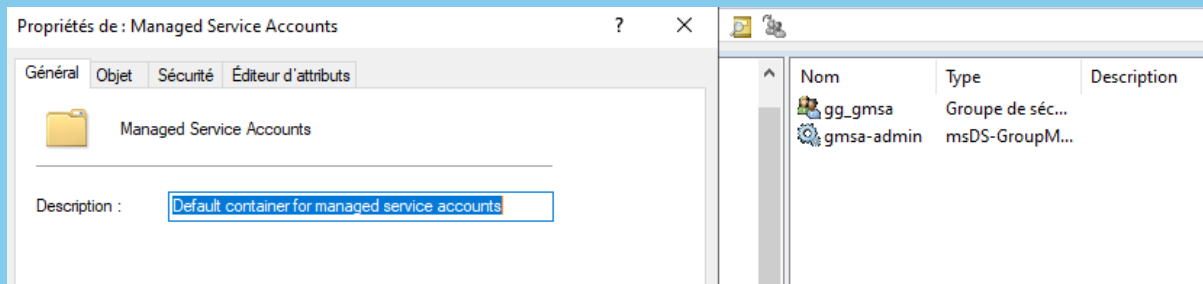


- **Protection spécifique** : Activation systématique de la pré-authentification Kerberos (notamment sur le compte d'Alice) pour empêcher la récupération de hash hors ligne.

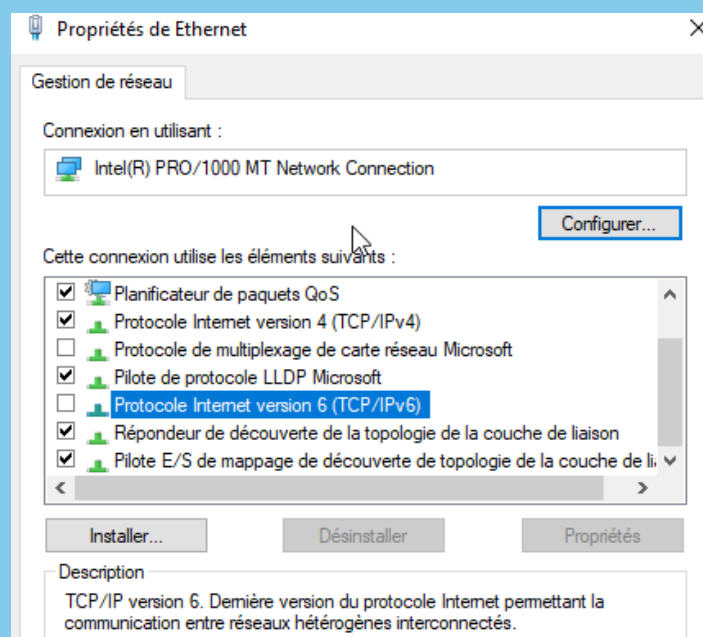


- **Gestion du compte de service** : Mise en place de comptes de service gérés par le groupe (GMSA) pour automatiser la rotation des mots de passe complexes des services.

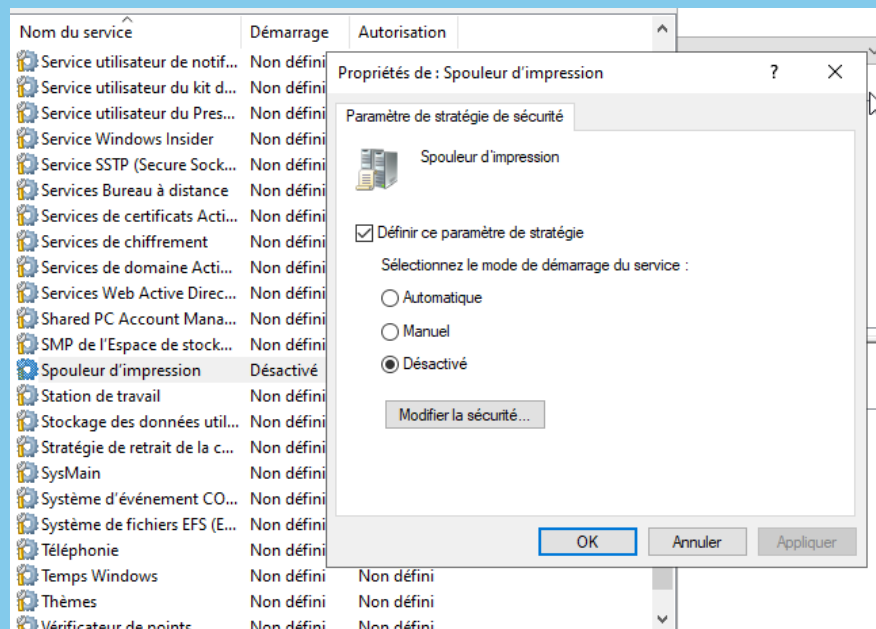
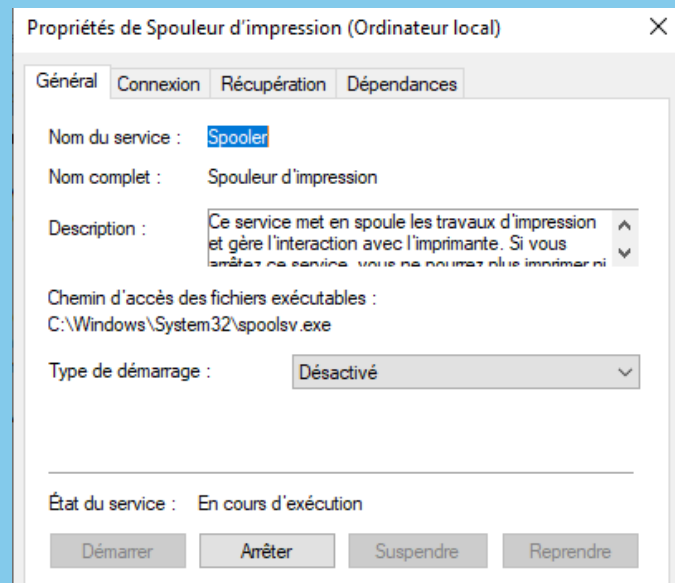
```
PS C:\Users\Administrateur> New-AdServiceAccount -Name "gmsa-admin" -DNSHostName "gmsa-admin.lab.local" -PrincipalsAllowedToRetrieveManagedPassword "gg_gmsa"
```



- **Désactivation IPV6 et Priorisation de l'IPv4** : L'IPv6 est activé par défaut sur tous les systèmes Windows modernes, il présente des risques de sécurité majeurs dans un réseau local qui n'est pas configuré pour le gérer.



- **Service spooler** : Le service d'imprimante a été désactivé



D. Protection des Postes et Administration Locale (LAPS)

- **Déploiement de LAPS** : Chaque poste de travail possède un mot de passe administrateur local unique et aléatoire, stocké de manière chiffrée dans l'AD. Cela empêche la propagation d'une attaque latérale si un poste est compromis.

LAPS			
Sélectionnez un élément pour obtenir une description.	Paramètre	État	Commentaire
	 Password Settings	Activé	Non
	 Name of administrator account to manage	Activé	Non
	 Do not allow password expiration time longer than required ...	Activé	Non
	 Enable local admin password management	Activé	Non

Password Settings

Paramètre précédent Paramètre suivant

☐ Non configuré Commentaire :
☒ **Activé**
☐ Désactivé

Pris en charge sur : At least Microsoft Windows Vista or Windows Server 2003 family

Options :

Password Complexity
 Large letters + small letters + numbers + specials

Password Length: 12
 Password Age (Days): 30

Aide :

Configures password parameters

Password complexity: which characters are used when generating a new password
Default: Large letters + small letters + numbers + special characters

Password length
Minimum: 8 characters
Maximum: 64 characters
Default: 14 characters

Password age in days
Minimum: 1 day
Maximum: 365 days
Default: 30 days

Name of administrator account to manage

Paramètre précédent Paramètre suivant

☐ Non configuré Commentaire :
☒ **Activé**
☐ Désactivé

Pris en charge sur : At least Microsoft Windows Vista or Windows Server 2003 family

Options :

Administrator account name
 bdupont@lab.local

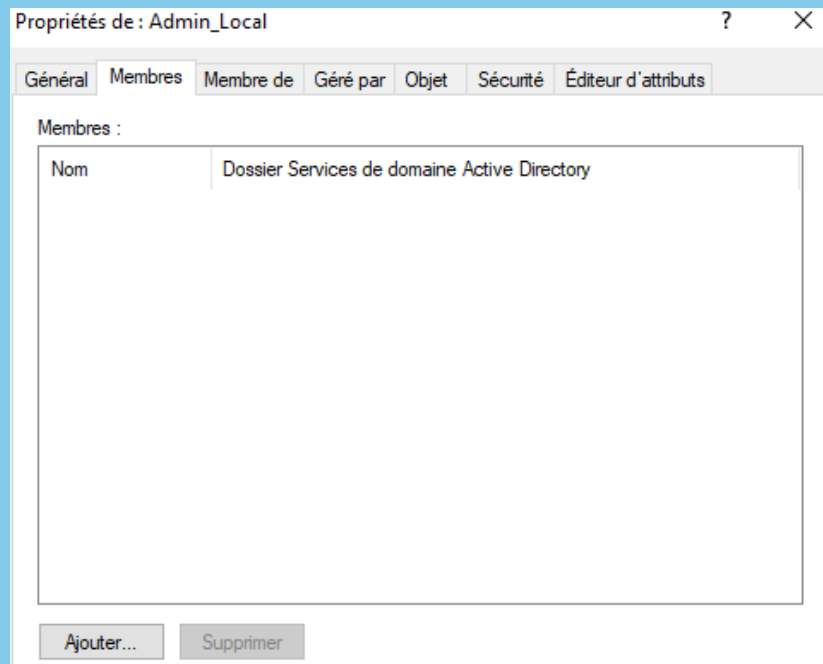
Aide :

Administrator account name: name of the local account you want to manage password for.
DO NOT configure when you use built-in admin account. Built-in admin account is auto-detected by well-known SID, even when renamed

DO configure when you use custom local admin account

Paramètre	État	Commentaire
Password Settings	Activé	Non
Name of administrator account to manage	Non configuré	Non
Do not allow password expiration time longer than required ...	Non configuré	Non
Enable local admin password management	Non configuré	Non

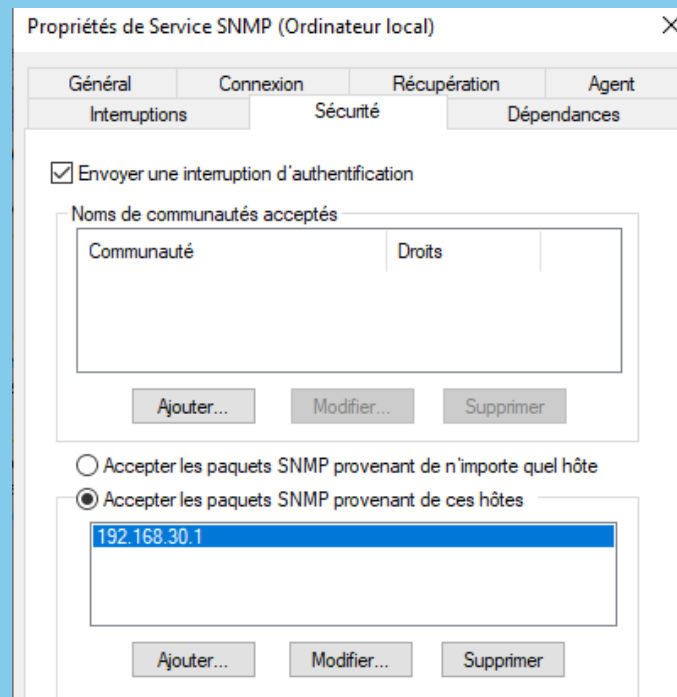
- **Restriction des privilèges** : Retrait des droits "Admin Local" pour les utilisateurs via GPO.



E. Sécurisation de la Supervision (SNMP)

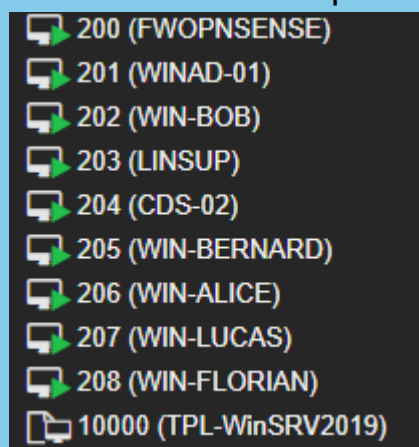
Les échanges avec Centreon ont été verrouillés :

- **Modification des paramètres** : Suppression de la communauté "public".
- **Filtrage d'hôte** : Restriction des paquets SNMP uniquement vers l'IP du serveur de supervision, refusant tout autre hôte.



F. Haute Disponibilité (Réplication)

- Un second contrôleur de domaine a été promu



Nom	Type	Type de contrôleur de domaine	Site	Description
DC1	Ordinateur	GC	Default-First-Site-Name	
DC2	Ordinateur	GC	Default-First-Site-Name	

6.6) Supervision et Métrologie (Centreon - Linsup)

La solution Centreon, installée sur une base Linux, a été **auditée**.

Plusieurs **failles de sécurité majeures** ont été identifiées et corrigées :

A. Configuration du système (Linsup) :

- **Gestion des accès SSH :** L'authentification par mot de passe a été désactivée car elle présente un risque élevé face aux attaques de force brute, seule l'authentification par paire de clés cryptographiques est désormais autorisée

```
florian-admin@LINSUP /1$ sudo vi /etc/ssh/sshd_config  
#PasswordAuthentication no #PermitRootLogin no
```

- **Désactivation du compte Root :** Le compte root a été verrouillé pour les connexions distantes.

```
florian-admin@LINSUP /1$ sudo passwd -l root  
Locking password for user root.  
passwd: Success  
florian-admin@LINSUP /1$ su root  
Password:  
su: Authentication failure  
florian-admin@LINSUP /1$
```

- **Création d'un utilisateur dédié :** Un utilisateur spécifique (florian-admin) a été créé. Il possède des droits étendus via la commande sudo, ce qui permet une traçabilité complète des actions d'administration.

```
florian-admin:x:1000:1000:~/home/florian-admin:/bin/bash
```

- **Nettoyage post-installation :** Sécurisation et suppression des fichiers de configuration temporaires contenant des informations sensibles, notamment le fichier ".tobesecured" qui exposait le mot de passe root en clair.

```
[root@LINSUP ~]# rm /etc/centreon/generated.tobesecured  
rm: remove regular file '/etc/centreon/generated.tobesecured'? yes  
[root@LINSUP ~]# cat /etc/centreon/generated.tobesecured  
cat: /etc/centreon/generated.tobesecured: No such file or directory
```

- **Filtrage Réseau** : L'accès à l'interface Web et au flux SSH est limité via l'OPNsense au seul VLAN 10 (ADMIN).
- **Politique de mots de passe système** : Obligation d'utiliser au minimum 12 caractères incluant majuscules, minuscules, chiffres et caractères spéciaux / Configuration d'une durée de vie maximale de 30 jours pour forcer le renouvellement / Avertissement de l'utilisateur 7 jours avant l'expiration du mot de passe / Après 3 tentatives de connexion le compte est automatiquement verrouillé pendant 30 minutes pour prévenir les attaques par brute force.

```

[florian-admin@LINSUP ~]$ vi /etc/pam.d/system-auth
[florian-admin@LINSUP ~]$ vi /etc/security/pwquality.conf
[florian-admin@LINSUP ~]$ vi /etc/login.defs
vi /etc/pam.d/etc/pam.d/password-authvi /etc/pam.d/system-auth
auth required pam_faillog.so preauth silent deny=3 unlock_time=1800
ocredit = 1 lcredit = 1 ucredit = 1 dcredit = 1 minlen = 12
PASS_MAX_DAYS 30
PASS_MIN_DAYS 0
PASS_WARN_AGE 7

```

- *Milen12* = nombre de 12 caractères minimum

- *Lcredit/ucredit/dcredit/ocredit* = 1 majuscule / 1 minuscule / 1 chiffre / 1 symbole

B. Configuration de CENTREON :

- **Faiblesse des identifiants** : Le compte "admin" de l'interface Centreon utilisait un identifiant/mot de passe par défaut, exposé aux attaques par dictionnaire.

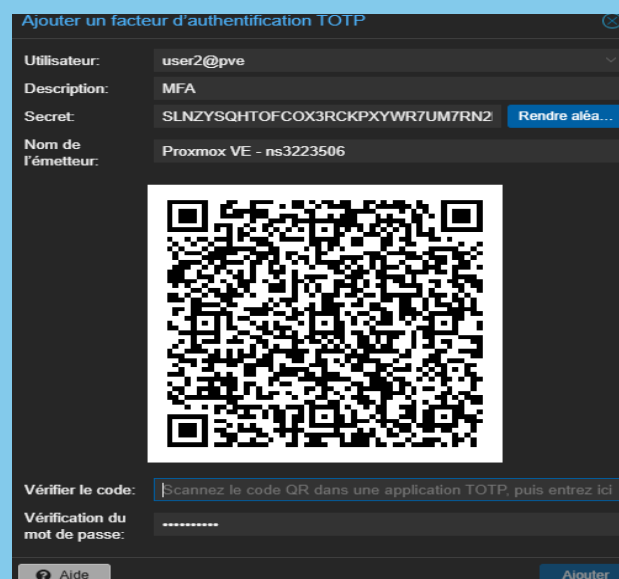
6.7) Sécurisation de l'Hyperviseur (Proxmox)

Proxmox constitue le **socle de l'infrastructure**. Sa sécurisation suit le principe de la "**Défense en profondeur**" pour éviter qu'une

compromission de l'hôte n'entraîne **la chute** de l'ensemble des serveurs virtuels.

A. Gestion des identités et des accès :

- **Double Authentification (2FA) :** L'accès à l'interface Web est protégé par un second facteur d'authentification. Même en cas de compromission du mot de passe, l'accès reste verrouillé sans le code à usage unique.



The screenshot shows a web form titled "Ajouter un facteur d'authentification TOTP". The form contains the following fields and elements:

- Utilisateur:** A dropdown menu with "user2@pve" selected.
- Description:** A text field containing "MFA".
- Secret:** A text field containing the alphanumeric string "SLNZYSQHTOFCOX3RCKPXYWR7UM7RN2". To its right is a blue button labeled "Rendre aléa...".
- Nom de l'émetteur:** A text field containing "Proxmox VE - ns3223506".
- QR Code:** A large square QR code is displayed in the center of the form.
- Vérifier le code:** A text input field with the placeholder text "Scannez le code QR dans une application TOTP, puis entrez ici".
- Vérification du mot de passe:** A password input field with masked characters "*****".
- Buttons:** At the bottom left is a grey button with a question mark icon and the text "Aide". At the bottom right is a blue button labeled "Ajouter".

B. Isolation et Filtrage réseau (Firewall) :

- **Pare-feu Proxmox :** Activation du pare-feu natif de l'hyperviseur pour n'autoriser les flux de gestion que s'ils proviennent des IP des postes de VLAN 10 - ADMIN.

Noeud 'ns3223506'		
Systeme	Éditer	
Réseau	Pare-feu	Oui
Certificats	Filtrer les paquets SMURF	Oui
DNS	Filtrer les flags TCP	Non
Hôtes	NDP	Oui
Options	nf_conntrack_max	Par défaut
Options	nf_conntrack_tcp_timeout_established	Par défaut
Heure	log_level_in	nolog
Pare-feu	log_level_out	nolog
Options	log_level_forward	nolog
Disques	tcp_flags_log_level	nolog
	smurf_log_level	nolog

Ajouter: Règle

Direction: in Activer: ☒

Action: DROP Macro:

Interface: Protocole:

Source: Port source:

Destination: Port de destination:

Commentaire: Blocage par défaut

Ajouter: Règle

Direction: in Activer: ☒

Action: ACCEPT Macro:

Interface: Protocole: tcp

Source: 192.168.10.0/24 Port source:

Destination: Port de destination: 8006,22

Commentaire: Autoriser Gestion VLAN10

- **Filtrage OPNsense** : Le pare-feu bloque toute tentative d'accès à l'IP de l'hyperviseur depuis les zones moins sécurisées.

C. Utiliser les "Notes" de Proxmox :

- L'utilisation de tags visuels permet une identification instantanée des ressources critiques, réduisant le risque d'arrêt accidentel lors des opérations de maintenance sur l'hyperviseur.

6.8) Sauvegardes et Stockage

La sauvegarde est **l'ultime rempart de la politique de sécurité** de PROSECUREX. Pour garantir une continuité d'activité **(PCA)** et une reprise après incident **(PRA)** optimales, j'ai déployé une stratégie de la règle **3-2-1** :

A. Principe de la règle 3-2-1

Cette méthode standard de l'ANSSI **garantit une disponibilité maximale** des données :

- **3 copies des données** : La production actuelle + deux copies de sauvegarde.
- **2 supports différents** : Stockage sur disque local et sur un serveur de sauvegarde dédié.
- **1 copie hors-ligne** : Exportation des sauvegardes critiques vers un stockage distant ou déconnecté du réseau de production.

B. Mise en œuvre avec Proxmox :

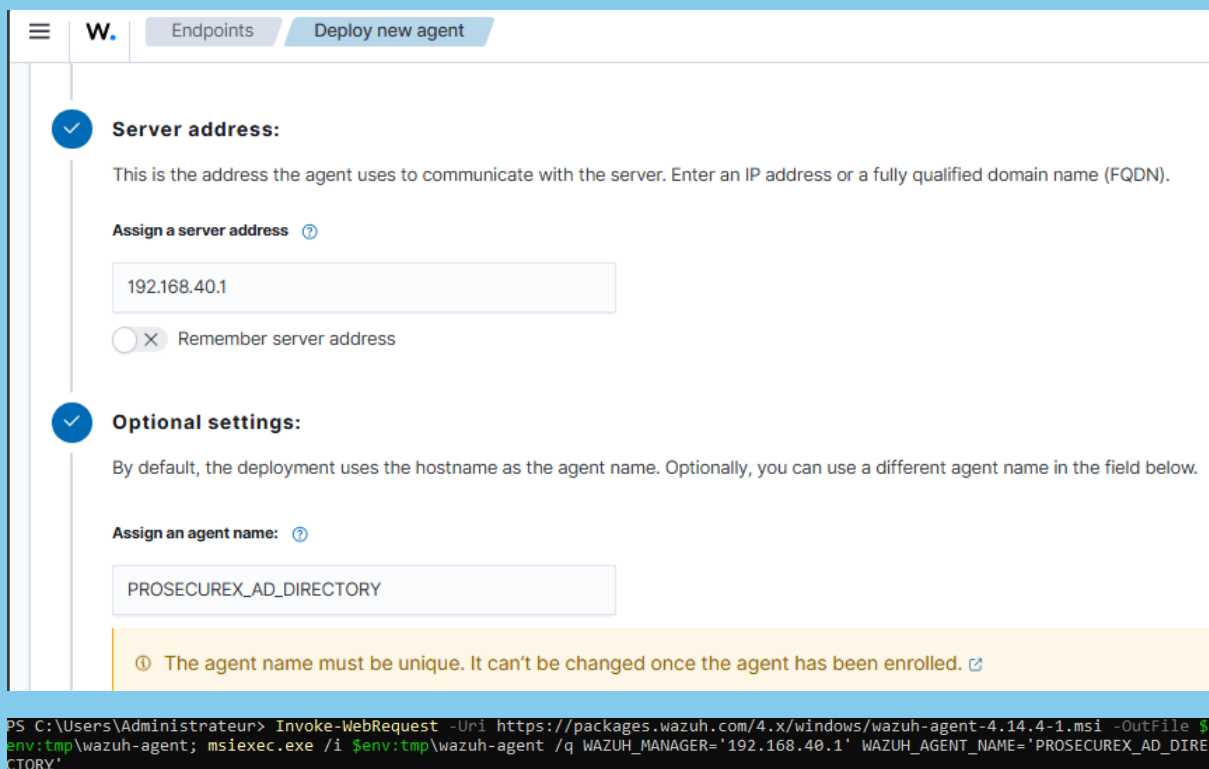
- **Immuabilité des données** : Utilisation des snapshots configurés en "Lecture seule". Même avec des accès administrateur, les sauvegardes ne peuvent être ni modifiées ni supprimées par un ransomware avant leur date d'expiration.
- **Chiffrement de bout en bout** : Les flux sont chiffrés avec une clé AES-256 avant de quitter l'hyperviseur, garantissant la confidentialité des données sur le Cloud ou le disque externe.
- **Déduplication et Intégrité** : Optimisation de l'espace disque et vérification hebdomadaire automatique de la santé des fichiers de sauvegarde.

C. Politique de Rétention et Restauration :

- **Fréquence** : Sauvegarde incrémentielle quotidienne à 02h00 pour minimiser l'impact sur la bande passante.
- **Rétention** : Conservation de 7 jours de sauvegardes journalières, 4 hebdomadaires et 1 mensuelle.
- **Objectif de Temps de Restauration (RTO)** : Grâce à la proximité du serveur et à la vitesse du stockage local, le rétablissement d'un service critique est garanti en moins de 30 minutes.

6.9) Audit de sécurité et Analyse des vulnérabilités

Surveillance du réseau par agent “WAZUH” sur chaque poste :



W. Endpoints Deploy new agent

✓ **Server address:**
This is the address the agent uses to communicate with the server. Enter an IP address or a fully qualified domain name (FQDN).

Assign a server address ?

192.168.40.1

☐ Remember server address

✓ **Optional settings:**
By default, the deployment uses the hostname as the agent name. Optionally, you can use a different agent name in the field below.

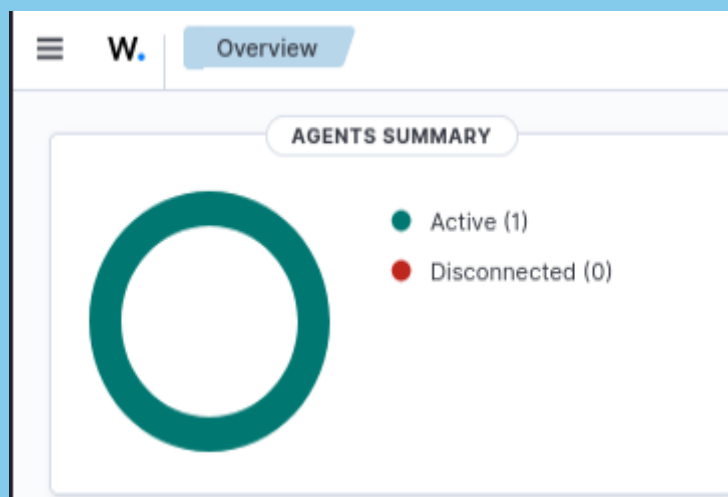
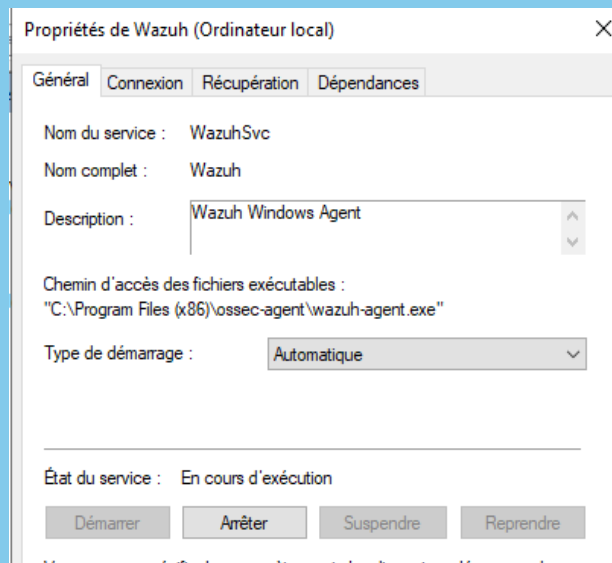
Assign an agent name: ?

PROSECUREX_AD_DIRECTORY

ⓘ The agent name must be unique. It can't be changed once the agent has been enrolled. ↗

```
PS C:\Users\Administrateur> Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.4-1.msi -OutFile $env:tmp\wazuh-agent; msiexec.exe /i $env:tmp\wazuh-agent /q WAZUH_MANAGER='192.168.40.1' WAZUH_AGENT_NAME='PROSECUREX_AD_DIRECTORY'
```

```
PS C:\Users\Administrateur> NET START Wazuh
Le service Wazuh démarre.
Le service Wazuh a démarré.
```

6.10) Vue d'ensemble des risques résiduels

Malgré la mise en œuvre d'une **stratégie de défense en profondeur** (**segmentation, durcissement, supervision**), l'infrastructure PROSECUREX reste **exposée à certains risques** qui ne peuvent être totalement éliminés par des solutions techniques.

A. Le facteur humain :

C'est le risque le plus important. Le pare-feu et le SIEM ne peuvent bloquer une action volontaire ou involontaire d'un utilisateur interne :

- **Phishing** : Un employé pourrait saisir ses identifiants sur un site frauduleux ou exécuter une pièce jointe malveillante, contournant ainsi les protections internes.
- **Erreur de manipulation** : Une mauvaise configuration manuelle ou la suppression accidentelle de données critiques par un administrateur.

B. Les menaces "Zero-Day" :

- L'infrastructure s'appuie sur des solutions logicielles.
- **Risque** : L'exploitation d'une vulnérabilité inconnue des éditeurs au moment de l'attaque. Bien que Wazuh détecte les CVE connues, il ne peut pas anticiper une faille pour laquelle aucun correctif n'existe encore.

C. Le vol ou le sinistre physique :

- Bien que les données soient répliquées, l'accès physique aux équipements reste un point de vigilance :
- **Accès aux locaux** : Si un individu malveillant accède physiquement au serveur Proxmox, il pourrait tenter d'extraire les données directement sur les disques.
- **Incident majeur** : Un incendie ou une inondation impactant simultanément la production et les sauvegardes locales.

D. Indisponibilité des liens WAN

La sécurité et la supervision dépendent de la connectivité réseau.

- **Risque** : Une coupure de la fibre optique ou une panne chez l'opérateur rendrait les services distants indisponible

6.11) Plan de remédiation et Recommandations

Le déploiement de l'infrastructure PROSECUREX a permis de **relever considérablement le niveau de sécurité**. Toutefois, pour **maintenir ce**

niveau de protection face à l'évolution des menaces, je préconise les actions suivantes :

A. Recommandations :

- **Sensibilisation des utilisateurs :** Organiser des sessions régulières de formation sur le phishing et la gestion des mots de passe. Un utilisateur averti est le premier pare-feu de l'entreprise.
- **Charte Informatique :** Rédiger ou mettre à jour une charte définissant les usages autorisés (clé USB, télétravail...) et les responsabilités de chacun.
- **Tests de restauration :** Planifier un test réel de restauration des sauvegardes (exercice de PRA) tous les 6 mois pour garantir que les données sur le Cloud sont exploitables en cas de crise.

B. Améliorations Techniques (Court/Moyen terme) :

- **Déploiement du MFA Généralisé :** Étendre l'authentification à deux facteurs (2FA) à l'ensemble des sessions Windows (via des solutions comme Duo ou Microsoft Authenticator) et pas seulement sur Proxmox.
- **Mise en place d'un HoneyPot :** Déployer un "pot de miel" (leurre) dans la DMZ pour attirer les attaquants et être alerté par Wazuh avant qu'ils ne touchent aux serveurs de production.
- **Gestion des mises à jour :** Automatiser totalement le déploiement des correctifs de sécurité sur les postes clients pour réduire la fenêtre d'exposition aux vulnérabilités CVE.
- **Mise en place d'un LAB :** Mettre en place un environnement de test pour éviter d'exploiter l'environnement de production lors de test.

C. Évolution vers le modèle "Zero Trust" :

À terme, l'entreprise devrait tendre vers une architecture Zero Trust (Ne jamais faire confiance, toujours vérifier) :

- **Micro-segmentation** : Affiner encore plus les règles de l'OPNsense pour isoler chaque service, même au sein d'un même VLAN.
- **Contrôle d'accès dynamique** : L'accès aux ressources ne doit plus dépendre uniquement de l'IP ou du VLAN, mais de l'état de santé du poste (antivirus à jour, identité vérifiée).

7) Conclusion et remerciements

Conclusion technique et personnelle :

Le projet PROSECUREX a permis de transformer une infrastructure standard en un environnement supervisé et sécurisé. À travers la mise en œuvre de la segmentation réseau, du durcissement système et de la mise en place d'un SIEM (Wazuh), l'objectif initial de "Défense en profondeur" a été atteint.

Ce que ce projet m'a apporté :

- **Expertise technique** : J'ai approfondi mes connaissances sur l'administration système Linux/Windows et la cybersécurité offensive/défensive.
- **Méthodologie** : Apprendre à auditer avant de configurer, et à documenter chaque flux réseau pour garantir la maintenabilité.
- **Vision globale** : Comprendre que la sécurité est une chaîne dont le maillon le plus faible (souvent l'humain) détermine la solidité de l'ensemble de l'infrastructure.

Ce projet **confirme mon souhait de m'orienter vers les métiers de l'administration système et de la cybersécurité**, où la veille technologique et la rigueur sont indispensables.

Remerciements :

Je tiens à remercier **toutes les personnes** qui ont contribué à la réussite de ce projet :

- **Mes formateurs / tuteurs** : Pour leur accompagnement pédagogique, leurs conseils techniques et leur disponibilité tout au long de la formation.
- **L'équipe de GUARDIA** : Pour m'avoir fourni les ressources et l'environnement nécessaires à la réalisation de ces maquettes.
- **Le jury** : Pour l'attention portée à la lecture de ce dossier et pour le temps accordé lors de ma présentation orale.